

國立成功大學
電機工程研究所
碩士論文

針對物聯網使用物理不可複製函數之具有硬體和韌體安
全性的 RISC-V 系統

Hardware and Firmware Secure RISC-V System using
Physical Unclonable Function for Internet of Things

研究生：謝憲譚

Student: Hsien-Hua Hsieh

指導教授：邱瀝毅 博士

Advisor: Lih-Yih Chiou, Ph.D.

Department of Electrical Engineering
National Cheng Kung University,
Tainan, Taiwan, R.O.C
Thesis for Master of Science

July, 2020

中華民國一百零九年七月

國立成功大學

碩士論文

針對物聯網使用物理不可複製函數之具有硬體和韌體安全性的RISC-V系統

Hardware and Firmware Secure RISC-V System using Physical Unclonable Function for Internet of Things

研究生：謝憲譚

本論文業經審查及口試合格特此證明

論文考試委員：

邱麗敏 郭致宏
陳中和 阮明華

指導教授：邱麗敏

系(所)主管：楊宏澤

中華民國 109 年 7 月 23 日

Hardware and Firmware Secure RISC-V System using Physical Unclonable Function for Internet of Things

By

Hsien-Hua Hsieh

A thesis submitted to the graduate division in partial
fulfillment of the requirement for the degree of
Master of Science

at

National Cheng Kung University
Tainan, Taiwan, Republic of China
July, 2020

Approved by :

Lilyth Chion
c. m. chen

Chen
Ming Hua Shen

Advisor :

Lilyth Chion

Chairman :

Ang-Ize Yang

針對物聯網使用物理不可複製函數之具有硬體和 韌體安全性的 RISC-V 系統

研究生：謝憲譚 指導教授：邱瀝毅 博士

國立成功大學電機工程研究所 VLSI/CAD 組

摘 要

物聯網(Internet of Things, IoTs)裝置近年來被廣泛地使用，裝置數量上升導致安全漏洞成為不可避免的問題。在傳統的物聯網裝置中會使用嵌入式非揮發性記憶體來儲存金鑰，但是嵌入式非揮發性記憶體有成本昂貴、面積過大且容易受到物理攻擊的缺點，相對的，強物理不可複製函數具有相對便宜與面積小的優點，且具有大量的挑戰響應對(challenge response pairs, CRPs)，物理不可複製函數成為一個適合取代嵌入式非揮發性記憶體的選項。但是少量的挑戰響應對洩漏會導致強物理不可複製函數被模型攻擊，最近也發展出幾種混和旁路攻擊和模型攻擊的方式，在未取得響應值的狀況下來建立強物理不可複製函數的模型，所以建立物理不可複製函數的保護機制是很重要的。

本論文提出一個具硬體和韌體安全性的 RISC-V 系統，使用進階加密標準伽羅瓦/計數器模式與物理不可複製函數建立裝置的信任根，並提出一個使用信任鏈的開機流程來保護韌體和針對駭客竊取金鑰攻擊模型的對策。根據實驗結果，反旁路攻擊可以使模型準確率有 28.85% 的降低幅度，並且讓響應值與功耗值的相關係數降低 85.7%。

關鍵字：物聯網、物理不可複製函數、旁路攻擊、模型攻擊

Hardware and Firmware Secure RISC-V System using Physical Unclonable Function for Internet of Things

Hsien-Hua Hsieh

Lih-Yih Chiou, Ph.D.

Department of Electrical Engineering

National Cheng Kung University,

Tainan, Taiwan, R.O.C

SUMMARY

Devices of Internet of Things (IoTs) are used worldwide in recent years. The increasing number of the devices makes the security vulnerability an unavoidable issue. Conventional devices of IoTs have used embedded Non-Volatile Memories (eNVMs) to store cryptographic keys. However, eNVMs are expensive, large and prone to physical attacks. In contrast, strong physical unclonable functions (PUFs) are relatively cheap and small with a large number of challenge and response pairs (CRPs). PUFs are suitable replacements of eNVMs for resource-limited IoT devices. Therefore, it is important to establish protection mechanism for PUFs. It will lead to model attack when a small number of CRPs leak. Recently, several hybrid-side channel (SC) and model attacks are proposed. Even if no responses are leaked, the adversary still can successfully build the strong PUF model.

We proposed a hardware and firmware secured RISC-V system. It used advanced encryption standard with Galois/Counter Mode (AES-GCM) and PUF to establish the Root of Trust (RoT). We also proposed a boot flow using Chain of Trust (CoT) as well as countermeasures against key extraction. According to the experimental results, the anti-SC attack would reduce accuracy of the PUF model attack by 28.85%. The correlation between model responses and power consumption is also reduced by 85.7%.

Key words: Internet of Things, Physical Unclonable Functions, Side-channel attack, Model attack

INTRODUCTION

Devices of Internet of Things (IoTs) are used worldwide in recent years. The increasing number of the devices makes the security vulnerability an unavoidable issue. Root of Trust (RoT) is a component offering one or several features of security, e.g., verification, and update. Moreover, RoT should guarantee its correctness of operations and usually is the first component of Chain of Trust (CoT). RoT can determine whether it can trust the next stage in CoT based on the results of verification. The next stage also verifies its succeeding stage, and so on. RoT could be an anchor of the CoT. Every stage can use the RoT to verify its next stage.

Conventional devices of IoTs have used embedded Non-Volatile Memories (eNVMs) to store cryptographic keys. However, eNVMs are expensive, large and prone to physical attacks. In contrast, emerging strong Physical Unclonable Functions (PUFs) are cheap, small with tremendous number of challenge and response pairs (CRPs). PUFs are suitable replacements of eNVMs for resource-limited IoT devices. It is important to establish protection mechanism for PUFs. It will lead to model attack when a small number of CRPs leak. Recently, several hybrid side channel and model attack are proposed. Even if no responses are leaked, the adversary still can successfully build the strong PUF model.

PROPOSED DESIGN

We propose a hardware and firmware secure RISC-V system. It has two 3-stage pipeline cores with RV32IMC instruction set of RISC-V: user core and privilege core. The user core will process normal data as well as execute operating system or applications. The privilege core is responsible for executing secure booting flow and trusted applications. The memory protection unit can control locks of the peripheral components which are used to control accesses from the user core. We use the bus matrix which consists of Advanced High-performance Bus Lite (AHB-Lite) to connect the components. The secure module has a 128-bit Advanced Encryption Standard Galois/Counter Mode (AES-GCM) co-processor, a 128-bit arbiter PUF, and a 128-bit complete Linear Feedback Shift Register (LFSR) used to generate sub-challenges for the arbiter PUF. We can use the arbiter PUF to generate a key for the AES-GCM. The main challenge will be sent to the LFSR to generate a sub-challenge. The PUF receives the sub-challenge and generates a 1-bit response. The PUF will be evaluated 128 times to generate a 128-bit response. The response represents the key of the AES-GCM.

To ensure the integrity of the firmware, we use the RoT which consists of the privilege core, secure module and boot ROM. The privilege core loads the encrypted firmware and sends to the secure module to decrypt and verify. Decrypted data is stored in on-chip RAM.

Furthermore, we also use the CoT to verify off-chip boot loader and operating system. After reset, the privilege core executes the unencrypted First Stage Boot Loader (FSBL) stored in boot ROM. Next, the FSBL loads the encrypted Second Stage Boot Loader (SSBL) stored in external flash memory and sends it to the secure module to decrypt. If the generated tag is identical to the loaded tag, the privilege core will execute the SSBL and verify integrity of the encrypted operation system. Otherwise, the boot process will be aborted.

The primary attack model of our system is key extraction. We assume that the adversary has the following abilities: awareness of the system architecture as well as physical access to the device. The later one means that the adversary is able to eavesdrop I/O of the system, craft malwares to run inside the user core, and perform power side channel attack to the system. The system has three different leakage channels. First, the adversary can use the user core to read out PUF responses. Because the adversary is aware of the system architecture and able to craft the malware run inside the user core, the adversary can directly use the user core to read out PUF responses. The countermeasure is that the privilege core uses MPU to build a trust execution environment after boot-up. It prohibits the user core from accessing the secure module. If the user core needs to use the secure module, it should assert a software interrupt to inform the privilege core. The privilege core can reject illegal accesses to the PUF. Second, the adversary can use the privilege core to inject malwares. Due to the restriction of the previous countermeasure, the user core cannot ask the privilege core to read out the PUF responses. However, the adversary can decrypt the firmware, inject malicious code, and re-encrypt the firmware by sending requests to the privilege core. The countermeasure is that the privilege core hashes the requested PUF challenge by the boot response and uses the hashed value as the AES key after boot up. This method makes encryption and decryption key different from the boot flow if the adversary uses the same challenge. Third, the adversary can use power side channel attack on key registers. Because malwares cannot read out PUF responses or inject malicious code, the adversary might extract the PUF response by side channel attacks. We assume that the adversary extracts PUF responses by power side channel attack. The key registers will be the primary attack target. The countermeasure is to make power consumption remain uniform. We use a differential arbiter PUF to generate two mutually exclusive responses in the same time. Moreover, we use complemental shift registers to latch the additional response. The adversary cannot obtain PUF responses by measuring total power consumption.

RESULTS AND DISCUSSION

We design an experiment to analyze the efficiency of balancing the power consumption. First, we use challenge and response pairs to train the PUF models of the standard arbiter PUF and the differential arbiter PUF. This gives us a basis of comparison for the next step.

We use Covariance Matrix Adaptation Evolution Strategy (CMA-ES) to train the PUF models. In the first step, we choose the error number of model responses as the fitness value of the model. Lower value stands for better result. The training results of the standard arbiter PUF and the differential arbiter PUF are shown in Figure 1 and Figure 2 respectively. The testing accuracy of the PUFs are 98.95% and 97.325% respectively.

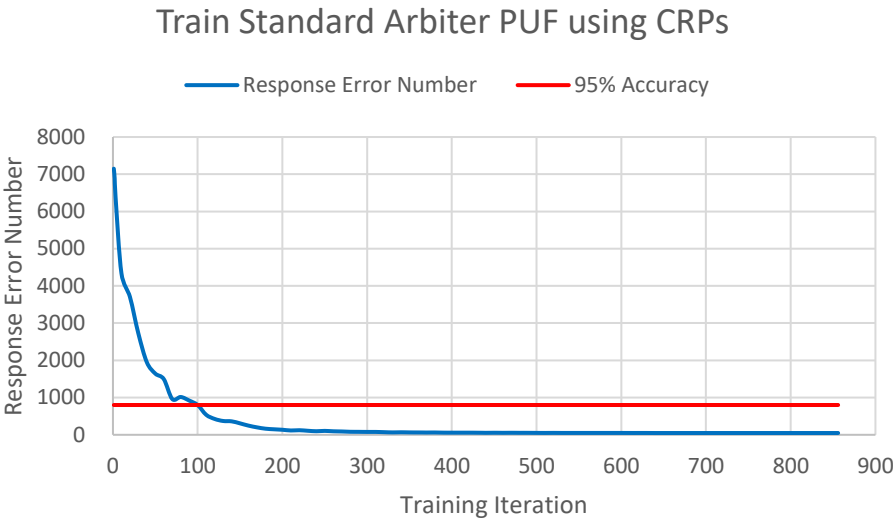


Figure 1. Train standard arbiter PUF using challenge and response pairs

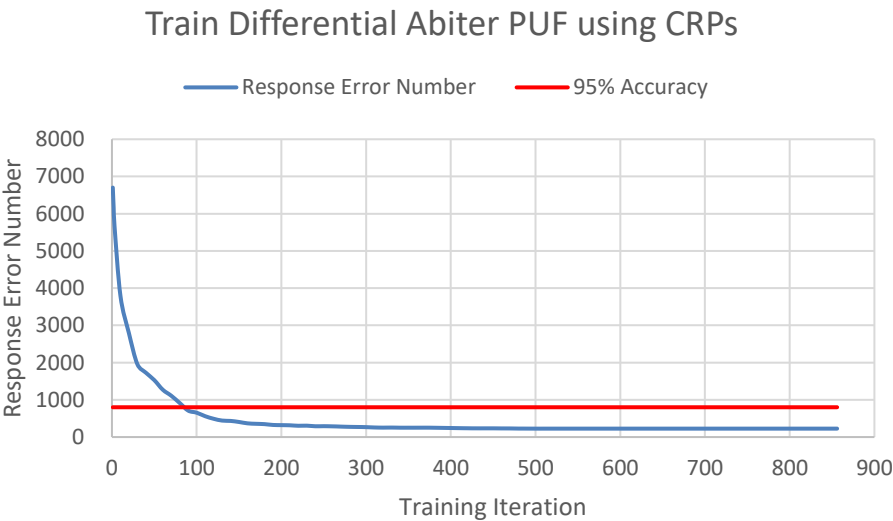


Figure 2. Train differential arbiter PUF using challenge and response pairs

Second, we use challenge and power consumption pairs to train the PUF models of the standard arbiter PUF and the differential arbiter PUF. This is the attack that the adversary could take. We choose the correlation between model responses and power consumption as the fitness value of the model. Values closer to 1 stand for better results. The training results

of the standard arbiter PUF and the differential arbiter PUF are shown in Figure 3 and Figure 4 respectively. The testing accuracy of the PUFs are 99.175% and 69.25% respectively.

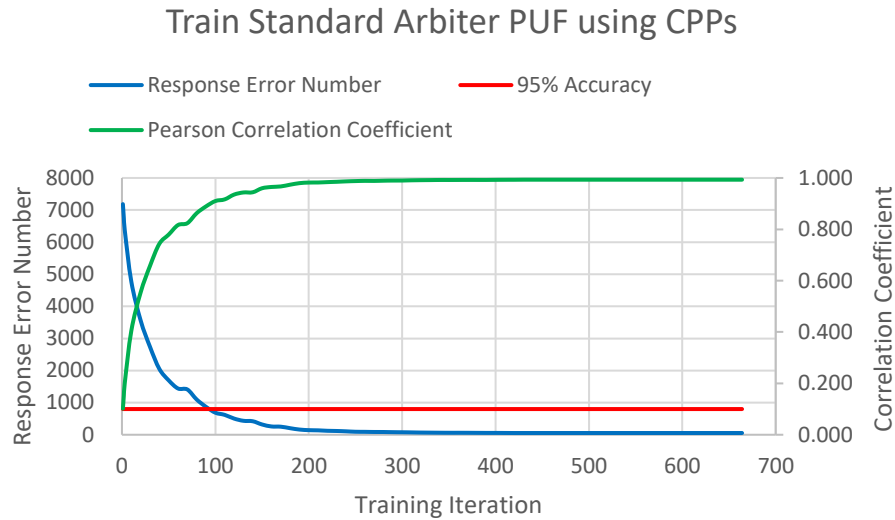


Figure 3. Train standard arbiter PUF using challenge and power consumption pairs

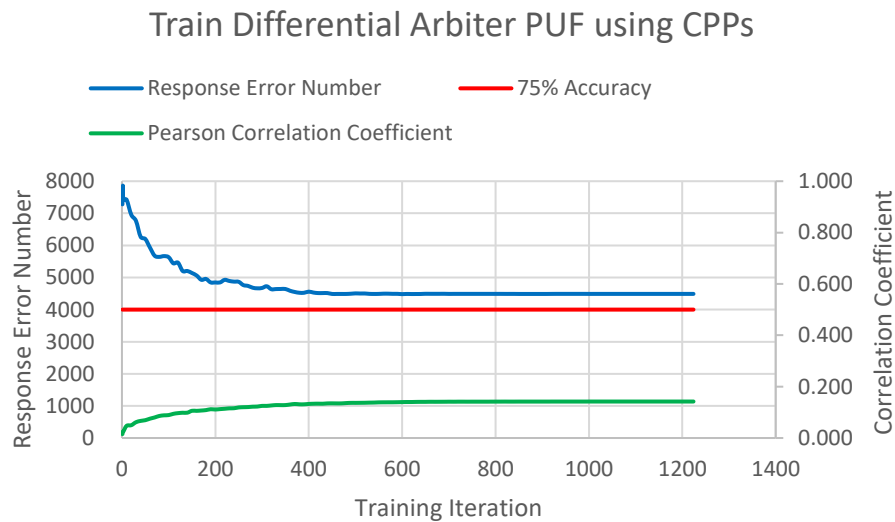


Figure 4. Train differential arbiter PUF using challenge and power consumption pairs

CONCLUSION

We propose a hardware and firmware secure RISC-V system using PUF for IoTs. In addition, we analyze the attack model of key extraction and its countermeasures. The RoT which provides device security consists of the privilege core, AES-GCM, PUF, MPU and peripheral locks. We also propose a secure boot flow to protect and verify the firmware using CoT. The attack model demonstrates three different leakage channels of keys. We use

hardware and firmware methods to protect the system and achieve the trust execution environment.

We design an experiment for the countermeasure against the power side channel attack. The model accuracy decreases to 69.25% by balancing the power consumption of the shift registers. The degradation ratio which compares to original accuracy is 28.85%. The degradation ratio of correlation between model responses and power consumption is 85.7%.



誌 謝

謝謝我的指導教授邱瀝毅老師，從大學時期課堂及專題就培養我的能力，讓我能為此篇論文打下基礎，碩士班時期的指導也讓我在專業知識及研究方法上能有更深入的認識及應用，在我研究遇到困難及瓶頸時也不吝給我建議，讓我能完成研究及本篇論文。同時也感謝口試委員陳中和老師、郭致宏老師以及許明華老師給予研究及論文上的建議，讓我能完善此篇論文。

感謝實驗室的學長姐：啟睿、朝凱、境昱、易溥、忠翰、宗翰、品修、維軒、俊興、晉維、哲彬、健棠、柏丞在我進入實驗室之後給我許多建議與幫助，讓我能克服研究路上的許多困難。也要感謝我的同學育緯、紀寬、昱宏、峻豪、唯宏，可以在遇到難題的時候互相給予幫助，在低潮時能夠互相給予勉勵，並且能順利度過碩士生涯。實驗室學弟妹志展、聖凱、錫峰、偉碩、宗蕙、Tenzing、韻如、琬筠、心妤、中凱、晨哲、鎮中、子毅，謝謝你們的幫忙讓我能完成我的研究及論文，祝你們未來一帆風順。

最後要感謝我的父母、哥哥及我的好友們，謝謝你們一直以來給予我支持、鼓勵與陪伴，讓我能夠順利地完成碩士班的學業，願你們與我共享這份喜悅，謝謝！

謝憲譚 謹誌

中華民國一百零九年 七 月 台南

目錄

摘要	i
誌謝	viii
目錄	ix
表目錄	xi
圖目錄	xii
第 1 章 緒論	1
1.1 研究背景	1
1.2 研究動機	3
1.3 研究貢獻	4
1.4 論文架構	5
第 2 章 相關研究背景	7
2.1 信任根與信任鏈	7
2.2 物理不可複製函數	9
2.2.1 物理不可複製函數種類及特性	9
2.2.2 模型攻擊	17
2.2.3 旁路攻擊	18
2.3 進階加密標準	21
第 3 章 相關文獻探討	25
3.1 攻擊物理不可複製函數	25
3.1.1 延遲加法模型	25
3.1.2 功耗分析旁路攻擊	26
3.2 安全開機流程	29
3.2.1 自我認證之安全開機	29

3.2.2	輕量級安全開機架構	32
3.3	相關文獻總結	34
第 4 章	具有硬體和韌體安全性的 RISC-V 系統	37
4.1	平台之環境與架構	37
4.1.1	微處理器架構	38
4.1.2	安全模組架構	39
4.1.3	記憶體保護元件與周邊鎖	40
4.2	韌體保護及認證機制	41
4.3	攻擊模型及反制方式	42
4.3.1	使用者核心讀出物理不可複製函數的響應值	43
4.3.2	特權核心植入惡意軟體	44
4.3.3	功率旁路攻擊分析金鑰暫存器	45
4.4	硬體及韌體安全	46
第 5 章	實驗結果與分析	49
5.1	實驗環境設置	49
5.1.1	實驗目標與對象	49
5.1.2	實驗工具與流程	49
5.1.3	機器學習方式	50
5.2	實驗結果	51
5.2.1	使用挑戰響應對訓練物理不可複製函數模型	51
5.2.2	使用挑戰功耗對訓練物理不可複製函數模型	53
第 6 章	結論和未來工作	55
6.1	結論	55
6.2	未來工作	56
	參考文獻	57

表目錄

表 3-1.	不同功率模型在不同雜訊下需要的挑戰數量及其準確率[27]	28
表 3-2.	相關文獻比較	35
表 5-1.	實驗工具	50
表 5-2.	自適應共變異數矩陣演化策略的參數設定	51
表 6-1.	本論文與相關文獻比較	55



圖目錄

圖 1-1.	物聯網裝置數量預測值[2]	1
圖 1-2.	近 10 年惡意軟體感染的數量[3]	2
圖 2-1.	信任根的運作方式[9]	7
圖 2-2.	ARM 的 TrustZone 架構[10].....	8
圖 2-3.	仲裁器物理不可複製函數架構[16]	10
圖 2-4.	互斥或仲裁器物理不可複製函數[15]	11
圖 2-5.	輕量級安全物理不可複製函數[18]	12
圖 2-6.	前饋式仲裁器物理不可複製函數[20]	13
圖 2-7.	逐漸逼近式類比數位轉換器物理不可複製函數[21]	14
圖 2-8.	靜態隨機存取記憶體單元[14]	15
圖 2-9.	環形振盪器物理不可複製函數[15]	16
圖 2-10.	控制物理不可複製函數[26]	19
圖 2-11.	伽羅瓦/計數器模式加密與認證訊息產生流程[37]	22
圖 2-12.	伽羅瓦/計數器模式解密與認證訊息驗證流程[37]	22
圖 3-1.	仲裁器物理不可複製函數(a)簡化前和(b)簡化後的交換器模型，以及(c)整體電路模型[20]	25
圖 3-2.	仲裁器物理不可複製函數的響應值儲存到暫存器的功率消耗[27]	27
圖 3-3.	仲裁器物理不可複製函數模型響應值與實際功耗的相關係數[27]	27
圖 3-4.	Xilinx 安全開機流程[39]	29
圖 3-5.	自我認證之安全開機流程[39]	30
圖 3-6.	自我認證之安全開機架構的攻擊模型[39]	31
圖 3-7.	輕量級安全開機架構[41].....	33
圖 3-8.	程式碼認證元件認證每一階段程式碼的流程[41].....	33

圖 3-9.	安全開機流程，(a)為一般軟體認證的開機流程，(b)為相關文獻提出的硬體認證開機流程[41]	34
圖 4-1.	具硬體和軟體安全性的 RISC-V 系統架構	38
圖 4-2.	SCR1 三階管線處理器架構[43]	39
圖 4-3.	使用物理不可複製函數為金鑰之進階加密標準—伽羅瓦/計數器模式的加密流程	40
圖 4-4.	使用物理不可複製函數為金鑰之進階加密標準—伽羅瓦/計數器模式的解密流程	40
圖 4-5.	記憶體保護裝置與周邊鎖架構，斜線為保護的部分	41
圖 4-6.	以(a)信任根及(b)信任鏈作為軟體的保護機制	42
圖 4-7.	使用者核心存取安全模組的反制方式	43
圖 4-8.	特權核心植入惡意軟體的反制方式，以(a)伽羅瓦/計數器模式為雜湊函式產生金鑰並進行(b)加密或解密的流程	44
圖 4-9.	平衡物理不可複製函數及金鑰暫存器功耗的架構	45
圖 4-10.	差動仲裁器物理不可複製函數架構	46
圖 4-11.	硬體及軟體安全	47
圖 5-1.	使用挑戰響應對訓練標準仲裁器物理不可複製函數	52
圖 5-2.	使用挑戰響應對訓練差動仲裁器物理不可複製函數	52
圖 5-3.	使用挑戰功耗對訓練標準仲裁器物理不可複製函數	53
圖 5-4.	使用挑戰功耗對訓練差動仲裁器物理不可複製函數	54



第 1 章 緒論

在本章節，首先會在 1.1 節介紹本論文之研究概觀，接著在 1.2 節和 1.3 節分別描述本論文之研究動機以及研究貢獻，最後在 1.4 節介紹本論文的組織架構。

1.1 研究背景

物聯網(Internet of Things)裝置近年來在世界各地被廣泛地使用[1]，透過自動控制單元及感測器與網路的連接，可以創造出多樣化的應用，隨著網路通訊的技術不斷地演進，物聯網可以將不同的人、事、時、地、物結合在一起，並且可以應用在家庭、士農工商業、國家級建設或軍事等不同的情境。物聯網裝置的數量在 2019 年已經有 80 億之多[2]，由於 2020 年 5G 網路晶片與基地台的推出，支援 5G 的物聯網裝置也會陸續生產及銷售，預計 2027 年裝置的數量會超過 410 億，預估趨勢如圖 1-1 所示。

FORECAST: Total IoT Device Installation Base
Billions, global

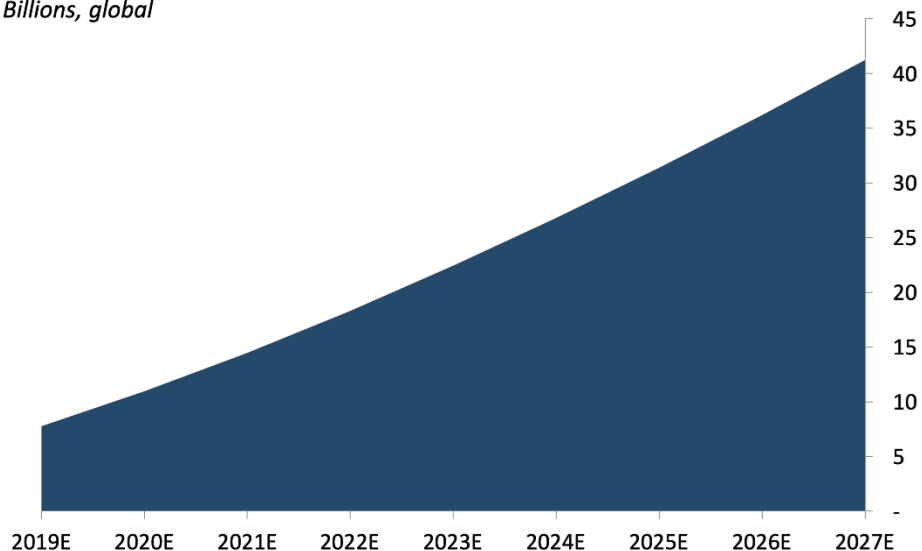


圖 1-1. 物聯網裝置數量預測值[2]

受惠於物聯網裝置的普及，機器學習(machine learning)及邊緣運算(edge computing)的技術成為近幾年熱烈討論的技術，前者因為晶片製作技術的演進，讓深層神經網路

(deep neural network, DNN)的訓練(training)更快速，物聯網裝置帶來的大量資料讓神經網路的模型可以更完善；後者是將運算從雲端轉移到裝置端的新興應用，受限於網路的傳輸速度，在裝置端進行運算可以加快處理及傳輸的速度，讓延遲降低，讓物聯網裝置可以應用在低延遲需求的情境，像是自動駕駛。

大量的物聯網裝置除了帶來巨量的經濟效益之外，同時帶來的安全性隱憂也非常嚴峻，因為物聯網裝置儲存的資料代表了個人或是公司的隱私，而控制單元則可能控制昂貴的機器、醫療照護等產品上，這些裝置被駭客控制可能會造成隱私、財務甚至生命上的損失，所以物聯網裝置的安全性是非常重要的議題。

如圖 1-2 所示，在 2018 年間惡意軟體的感染數量超過 8 億[3]，平均每一天有 8 萬多起網路攻擊事件發生。由於物聯網裝置通常是嵌入式系統(embedded system)，如果製造商在設計過程中沒有考量到安全性的問題或是考量不周全，就會讓物聯網裝置容易受到攻擊，在 2016 年時發生一起使用 Mirai 殭屍網路的大型阻斷服務攻擊(distributed denial-of-service, DDoS)[4]，就是利用裝置預設的帳號密碼來登入物聯網裝置，並且同時發動攻擊。

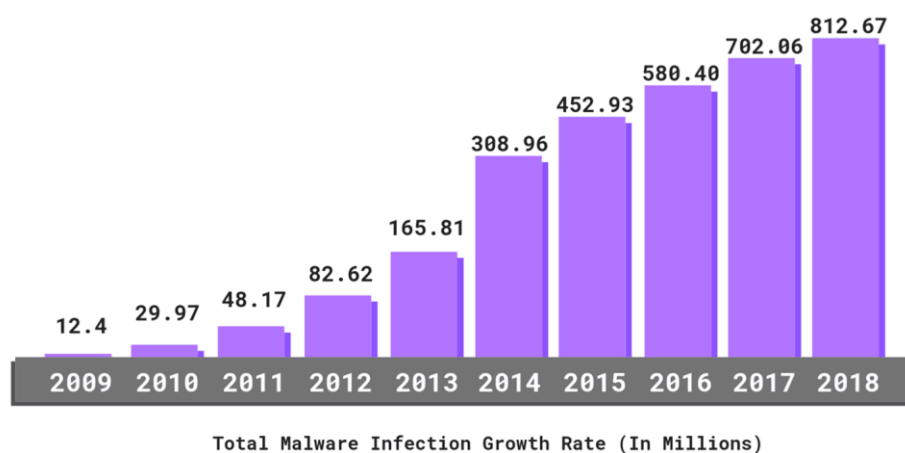


圖 1-2. 近 10 年惡意軟體感染的數量[3]

據美國國家標準暨技術研究院(National Institute of Standards and Technology, NIST)提出的報告[5]，物聯網裝置必須具有以下幾種功能：裝置識別(device identification)、

裝置配置(device configuration)、裝置保護(device protection)、邏輯存取介面(logical access to interfaces)、軟體更新(software update)、網路安全狀態意識(cybersecurity state awareness)。受限於物聯網裝置的大小及成本，如何在有限的資源下達成更高的安全性是必須探討的問題。

1.2 研究動機

如前所述，物聯網裝置的安全性是一個重要的議題，駭客可能會偷取隱私資料或是取得裝置控制權，一般會透過信任根(root of trust)來保護裝置，像是使用密碼雜湊函式(cryptography hash function)及非對稱金鑰演算法(asymmetric-key algorithm)驗證資料、程式的完整性，確保使用的程式或資料沒有被竄改過；或是使用對稱金鑰演算法(symmetric-key algorithm)來保護輸出或是輸入的資料。因為金鑰儲存在晶片外部(off-chip)會造成很大的安全隱憂，一般會使用嵌入式非揮發性記憶體(embedded non-volatile memory, eNVM)來儲存金鑰，但是使用嵌入式非揮發性記憶體可能會造成幾個問題，第一個問題為可能會使用額外的光罩及製程步驟，造成成本的上升；第二個問題為如果使用唯讀記憶體(read-only memory, ROM)或是可程式化唯讀記憶體(programmable read-only memory, PROM)存放金鑰，會分別出現裝置金鑰共用或面積過大的狀況；第三個問題為非揮發性記憶體已經被證明容易受到物理攻擊(physical attack)[6]。

物理不可複製函數(physical unclonable function, PUF)為一個適合取代非揮發性記憶體的元件，它是一種類似人類指紋的特殊元件，利用晶片製程的變異讓每個元件的輸入及輸出行為產生差異。有許多物理不可複製函數類型可以使用互補式金屬氧化物半導體(complementary metal-oxide-semiconductor, CMOS)製程製作出來，像是延遲型物理不可複製函數(delay-based PUF)、靜態隨機存取記憶體型物理不可複製函數(SRAM-based PUF)、電容型物理不可複製函數(capacity-based PUF)，不會使用到額外

的光罩及製程步驟；物理不可複製函數擁有一組至多組挑戰響應對(challenge-response pairs, CRPs)，可以提供使用上的彈性；因為物理不可複製函數的秘密藏在晶片架構內，無法輕易地取出變異的參數，侵入式攻擊(invasive attack)也可能會破壞其中的秘密。

物理不可複製函數雖然有機會替代非揮發性記憶體，但是近幾年的研究發現物理不可複製函數容易被模型攻擊(modeling attack)[7]，如果駭客取得足夠數量的挑戰響應對，就可以重建出高精確度的軟體模型，近期也發展出一些混和旁路攻擊(side-channel attack)和模型攻擊的方式[8]，讓物理不可複製函數面對更多的威脅。

綜合以上所述，在資源有限的物聯網裝置上，使用物理不可複製函數當成安全元件比非揮發性記憶體更有優勢，但是建立保護物理不可複製函數的機制是非常重要的，本論文使用物理不可複製函數當成裝置的信任根，並且結合硬體及軟體的方式保護系統。

1.3 研究貢獻

本論文提出一個針對物聯網使用物理不可複製函數之具有硬體和軟體安全性的 RISC-V 系統，本系統具有以下特點：

- 使用進階加密標準伽羅瓦/計數器模式 (Advanced Encryption Standard – Galois/Counter Mode, AES-GCM)與物理不可複製函數建立裝置的信任根
- 使用信任鏈的開機流程保護軟體
- 駭客竊取金鑰的對策
 - 安全執行程式的環境
 - 抵抗功耗分析旁路攻擊(power side-channel attack)

1.4 論文架構

本論文分成六章，第一章介紹研究概觀、研究動機以及與研究貢獻；第二章針對信任根與信任鏈、物理不可複製函數、使用模型攻擊仲裁器物理不可複製函數(arbiter PUF)的方式、混和旁路攻擊和模型攻擊物理不可複製函數的方法等相關背景知識進行介紹；第三章探討與本論文相關的文獻；第四章說明本論文提出之具有硬體和軟體安全性的 RISC-V 系統，並且提出攻擊模型(attack model)及防治方式(countermeasure)；第五章介紹實驗環境設置及探討物理不可複製函數的訓練結果；第六章提出本論文的結論與未來研究方向。





第 2 章 相關研究背景

本章節介紹本論文的相關知識與背景，在 2.1 節對信任根與信任鏈做背景及原理的介紹，在 2.2 節對物理不可複製函數的種類、特性及攻擊方式做介紹，在 2.3 節對進階加密標準及伽羅瓦/計數器模式做介紹。

2.1 信任根與信任鏈

要確保裝置的安全性，首先就要確保裝置的韌體和作業系統是可信任(trusted)、沒有被竄改(tampered)的，信任根的概念由此而產生。信任根是一個提供一種或數種安全功能的元件[9]，像是驗證或升級等功能，且必須確保其運作的正確性。如圖 2-1 所示，信任根通常是信任鏈(chain of trust)的第一個元件，信任根可以根據驗證的結果決定是否可以信任下一級，而下一級再驗證後一級是否可以信任，以此類推形成一條信任鏈。信任根也可以擔任信任鏈的錨點(anchor)，每一級可以利用信任根來驗證後一級，不局限於只擔任首次驗證的角色。

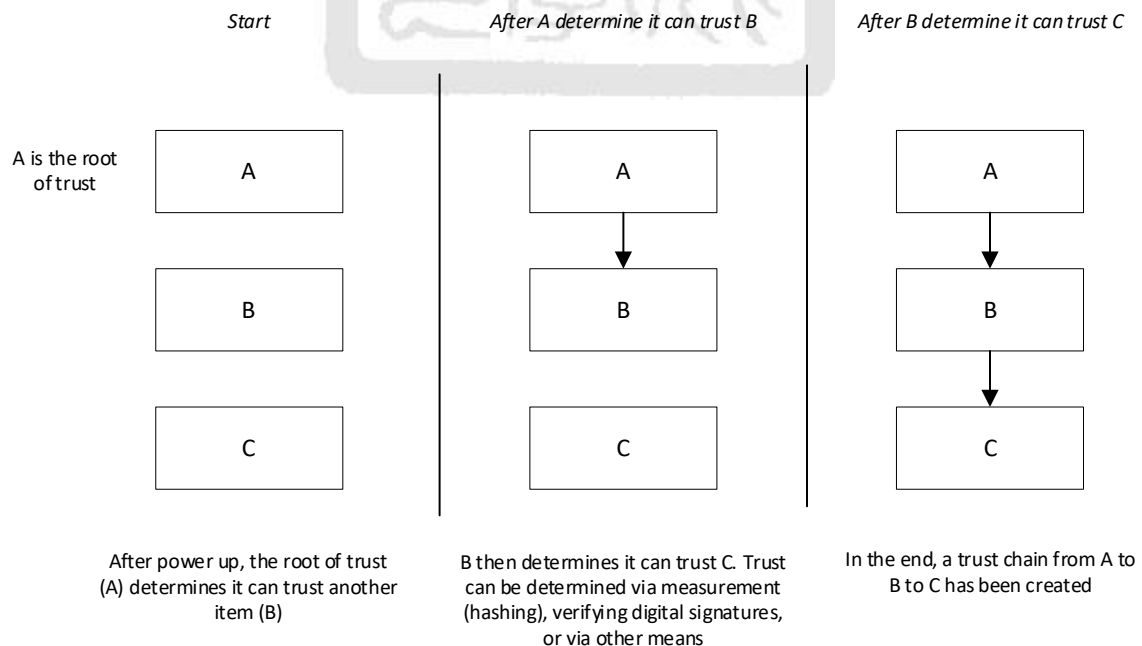


圖 2-1. 信任根的運作方式[9]

舉例來說，ARM 的 TrustZone 建立在安全世界(secure world)和非安全世界(non-secure world)上[10]如圖 2-2 所示，透過處理器、匯流排和周邊的硬體邏輯把兩個世界分開，安全世界運行安全軟體來執行可信任的開機流程、兩個世界切換的偵測及其他一些可信任的程式，來形成可信任的執行環境(trusted execution environment, TEE)。AMD 的平台安全處理器(platform security processor, PSP)[11]是使用 ARM 的 TrustZone，為加速處理單元(accelerated processing units, APUs)提供一個安全執行環境。Intel 的 Boot Guard 使用硬體保護開機的完整性[12]，避免未經授權的軟體或是惡意軟體影響系統安全。

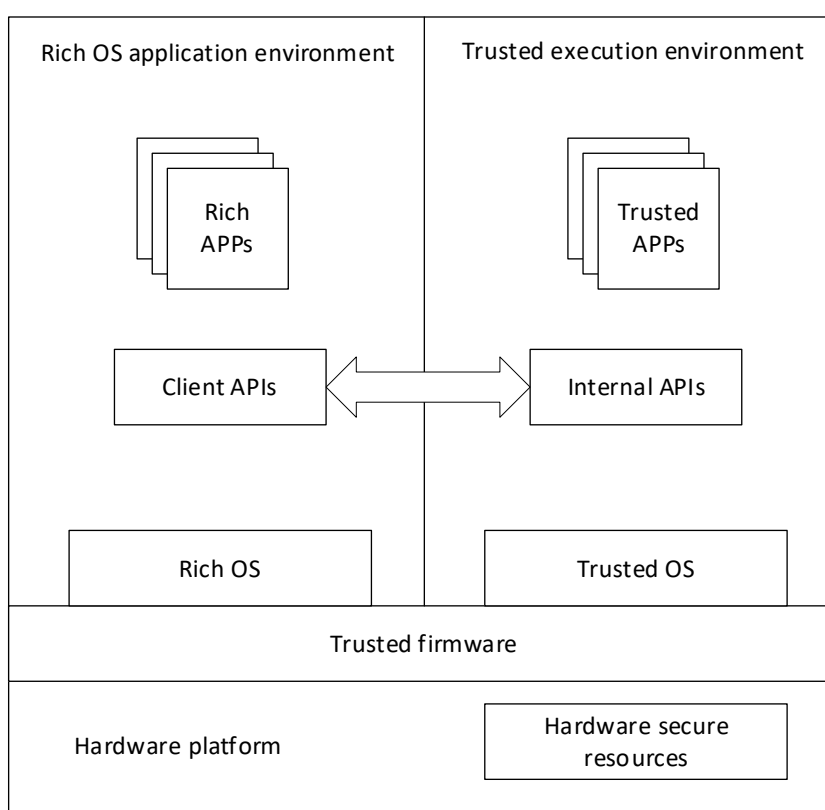


圖 2-2. ARM 的 TrustZone 架構[10]

2.2 物理不可複製函數

如 1.2 節所述，物理不可複製函數利用晶片製程的變異讓每一個元件的輸入及輸出行為產生差異，一個 x 位元輸入、 y 位元輸出的物理不可複製函數， x 代表挑戰 c 、 y 代表響應 r ，物理不可複製函數的行為並不是完全隨機的[13]，首先，因為響應值來自物理不可複製函數的物理架構，不同挑戰所產生的響應之間有關聯性(correlation)；受到製程變異的影響，每一個物理不可複製函數都會產生不同的偏移量(bias)，響應為 0 或是 1 的機率並不完全相同；最後，因為幾乎所有物理不可複製函數都容易受到外在環境和雜訊影響，每次產生的挑戰響應對並不一定完全相同。要將物理不可複製函數當成密碼學的用途，必須要做一些處理才可以使用。

2.2.1 物理不可複製函數種類及特性

物理不可複製函數通常以挑戰響應對的數量分成弱物理不可複製函數(weak PUF, WPUF)及強物理不可複製函數(strong PUF, SPUF)。弱物理不可複製函數挑戰響應對的數量與所需要的晶片面積大約成線性比例，通常由多個相同的元件組成一個陣列，陣列地址為 N 個位元的挑戰值，元件輸出為 M 個位元的響應值，靜態隨機存取記憶體物理不可複製函數(SRAM PUFs)[14]和環形振盪器物理不可複製函數(ring oscillator PUFs)[15]為其中的代表。強物理不可複製函數挑戰響應對的數量與所需要的晶片面積大約成指數比例，通常由兩組相同的陣列組成， N 個位元的挑戰值通常用於開關或是切換陣列內的元件，兩組陣列會進行比較產生 M 個位元的響應值，仲裁器物理不可複製函數[16]為其中的代表。

在一般的情況下，弱物理不可複製函數的 N 值會小於強物理不可複製函數、 M 值則相反，因此弱物理不可複製函數通常用於產生裝置的密鑰，而強物理不可複製函數通常用於輕量級認證協定(lightweight authentication protocol)，此類型協定傾向不使用複雜的密碼學演算法，單純利用強物理不可複製函數擁有大量的挑戰響應對，讓驗

證端(verifier)確定裝置端(token)的身分沒有被竄改，但因為強物理不可複製函數的挑戰響應對具有強烈的關聯性，只需要少量暴露的挑戰響應對，即可以用模型攻擊的方式重建精確度很高的軟體模型[16]，模型攻擊的方式會在 2.2.2 節進行介紹。

以下介紹幾種常見以互補式金屬氧化物半導體製程為主的不可複製函數架構以及特性：

仲裁器物理不可複製函數[16]：

仲裁器物理不可複製函數是由 N 個交換器(switch)所組成的，每一個交換器是由兩個多工器(multiplexer)所形成，交換器的訊號最後會傳入門鎖(latch)形成的仲裁器，如圖 2-3 所示，挑戰值 c 用來切換交換器的狀態，當該級交換器的挑戰為 0，訊號會直接傳入下一級，反之訊號會上下交換後才傳入下一級，交換器的狀態設定好之後，「開始」訊號會由 0 轉態成 1，最後仲裁器根據上下兩條訊號到達的時間決定輸出的響應值 r 。仲裁器物理不可複製函數可以提供 2^N 組挑戰響應對，每組響應的位元數 M 為 1，屬於強物理不可複製函數。

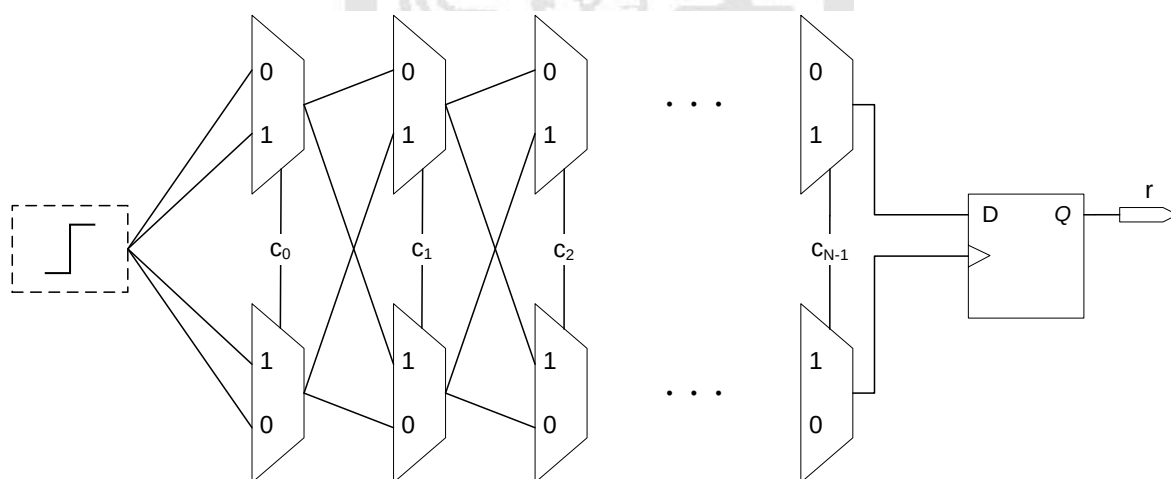


圖 2-3. 仲裁器物理不可複製函數架構[16]

仲裁器物理不可複製函數利用不同的延遲時間組合成兩組值進行比較，是最常被使用的物理不可複製函數，也經常被當成其他物理不可複製函數的基本元件，這些物

理不可複製函數的目的都是要增加仲裁器物理不可複製函數的複雜度，使元件更不容易被模型攻擊。

互斥或仲裁器物理不可複製函數(XOR arbiter PUFs)[15]：

互斥或仲裁器物理不可複製函數為兩個以上的仲裁器物理不可複製函數組合而成，全部仲裁器物理不可複製函數的輸出會經過互斥或運算，挑戰值 c 用來切換每一個仲裁器物理不可複製函數的交換器，互斥或的輸出為響應值 r 。互斥或仲裁器物理不可複製函數可以提供 2^N 組挑戰響應對，每組響應的位元數 M 為 1，屬於強物理不可複製函數。

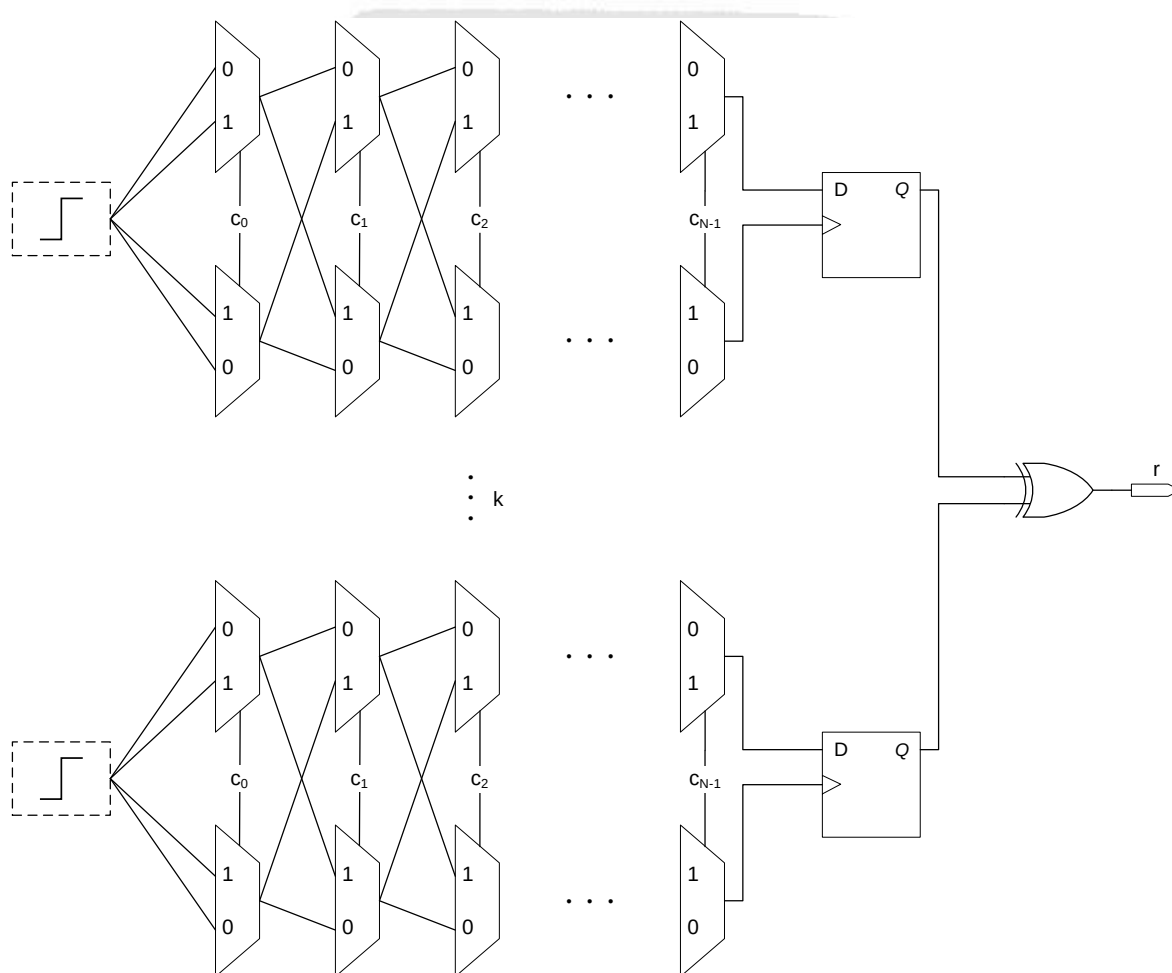


圖 2-4. 互斥或仲裁器物理不可複製函數[15]

互斥或仲裁器物理不可複製函數可以使模型攻擊的難度成指數型上升[7]，但是過多的互斥或會導致可靠度(reliability)下降，而且也不能完全避免模型攻擊[17]。

輕量級安全物理不可複製函數(Lightweight Secure PUFs)[18]：

輕量級安全物理不可複製函數也是由多個仲裁器物理不可複製函數組合而成，如圖 2-5 所示，此架構依序分成四個部分：互連網路、輸入網路、仲裁器物理不可複製函數、輸出網路，互連網路交換挑戰值 c 傳輸到下一級的位元順序，讓每一個輸入網路都使用不同的 c_k ；輸入網路將 c_k 變換成 c_k^* ，除了把 c_k 相鄰的位元分散之外，也確保 c_k 的每一個位元會影響 c_k^* 一個或兩個位元的值；仲裁器物理不可複製函數則根據輸入的挑戰值 c_k^* 來產生響應值 r_k ；輸出網路則會從 r_k 選取連續 x 組響應值做互斥或得到最後的響應值 r_M ，每一組 r_M 選取的起始 r_k 會比前一組往後位移一個順位，最後會產生 M 組不同的響應值。輕量級安全物理不可複製函數可以提供 2^N 組挑戰響應對，每組響應的位元數 M 最少為 1、最多為 N ，屬於強物理不可複製函數。

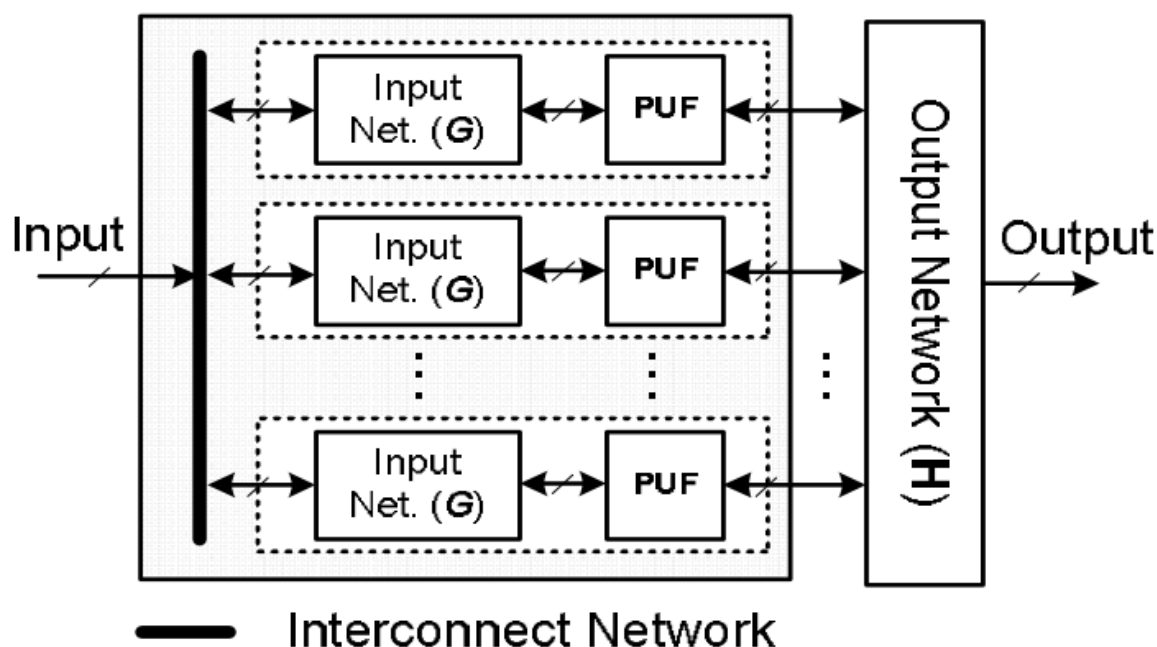


圖 2-5. 輕量級安全物理不可複製函數[18]

輕量級安全物理不可複製函數的互斥或數量大於互斥或仲裁器物理不可複製函數，所以對模型攻擊有更高的抵抗性，但是內部響應值 0 和 1 的數量如果經由旁路攻擊洩漏出去[19]，反而會比互斥或仲裁器物理不可複製函數更容易被模型攻擊。

前饋式仲裁器物理不可複製函數(Feed-Forward Arbiter PUFs)[20]：

前饋式仲裁器物理不可複製函數更改了標準仲裁器物理不可複製函數的架構，在傳輸路徑上多插入一些交換器，這些交換器由前面幾級傳輸的快慢來決定是否要切換，前幾級的輸出會傳入額外的仲裁器，這些仲裁器負責切換交換器，形成前饋迴圈(feed-forward loop)，如圖 2-6 所示。前饋式仲裁器物理不可複製函數可以提供 2^N 組挑戰響應對，每組響應的位元數 M 為 1，屬於強物理不可複製函數。

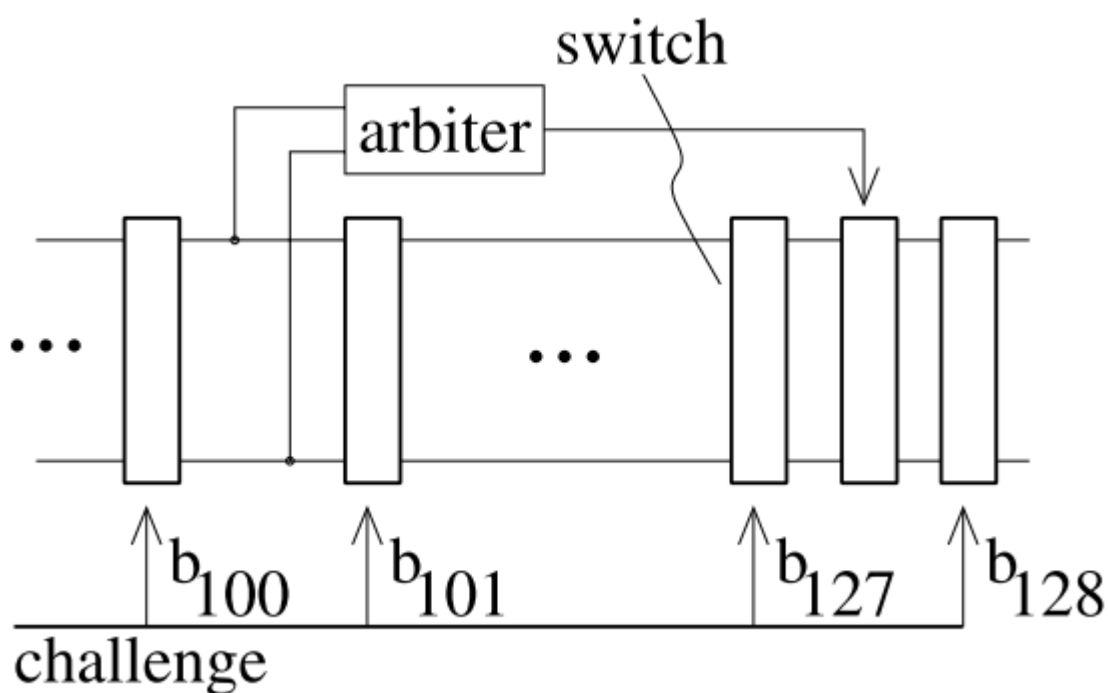


圖 2-6. 前饋式仲裁器物理不可複製函數[20]

前饋式仲裁器物理不可複製函數對模型攻擊的抵抗性取決於前饋迴圈的數量[7]，因為前饋迴圈帶來的非線性關係，讓許多線性分類的模型攻擊失效。

逐漸逼近式類比數位轉換器物理不可複製函數(successive-approximation analog to digital converter PUFs, SAR-ADC PUFs)[21]：

逐漸逼近式類比數位轉換器物理不可複製函數由逐漸逼近式類比數位轉換器架構轉變而來，由 2 組對稱的加權電容陣列(weighted capacitor array)組成，總共會有 $N + 1$ 對電容，同一組陣列上的電容值除了充電用的第 0 對固定為 C 之外，第 1 對到第 N 對的電容值為 2 的等比級數($C, 2C, 4C, \dots$)，用來進行電荷共享(charge sharing)的運算，每一對電容都有一個開關可以選擇接地(ground)、接電源(V_{DD})或是浮接(floating)，另外一頭則是將所有電容連接在一起，並且有一個開關 S_{VCM} 決定是否要連接到共同電源 V_{cm} ，兩個陣列的電壓值則會經由比較器(comparator)決定輸出的狀態，整體架構如圖 2-7 所示。挑戰值 c 用來決定每一對電容是否要參與接下來的運算，沒被開啟的電容需要全程保持在浮接的狀態，一開始只有第 0 對電容接地，其他開啟的電容都接電源，開關 S_{VCM} 保持導通為電容充電，充完電之後開關 S_{VCM} 斷開進行電荷共享，第 0 對電容改成接電源，換下一對開啟的電容接地，接下來以此類推，每一次只有一對電容會接地，其他電容都接電源，做完之後兩個陣列的電壓會進行比較，產生出響應值 r 。逐漸逼近式類比數位轉換器物理不可複製函數可以提供 2^N 組挑戰響應對，每組響應的位元數 M 為 1，屬於弱物理不可複製函數。

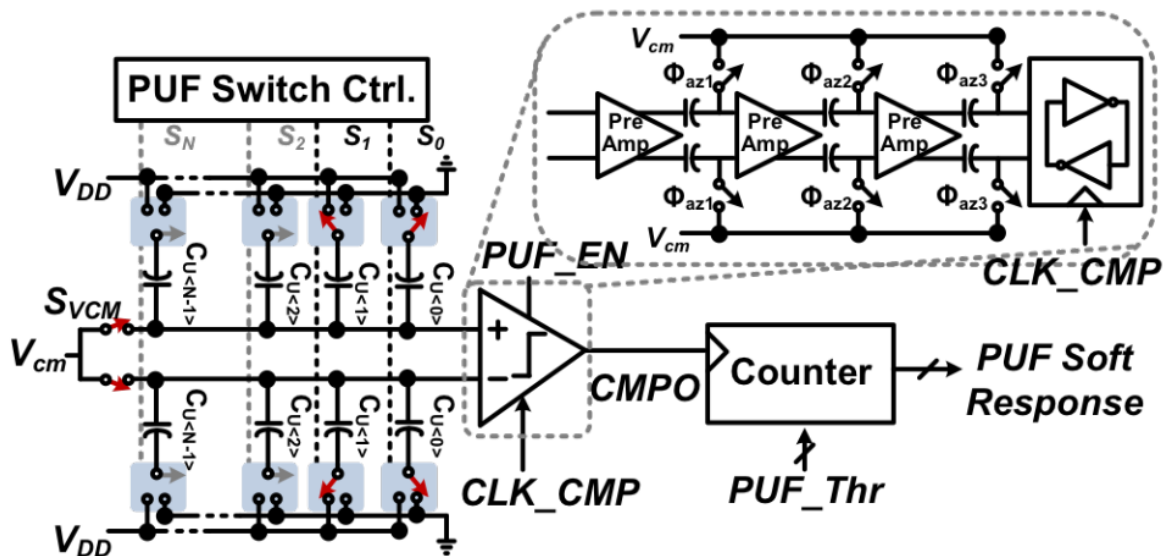


圖 2-7. 逐漸逼近式類比數位轉換器物理不可複製函數[21]

逐漸逼近式類比數位轉換器物理不可複製函數利用電容的變異性來影響輸出的結果，與前面幾種利用延遲時間的方式不同，因為使用的電容值成等比級數增加，且電容佔據晶片的面積過於龐大，導致其成為弱物理不可複製函數，如何縮減電容的面積會是此類型物理不可複製函數發展的關鍵，甚至可以發展成強物理不可複製函數。

靜態隨機存取記憶體物理不可複製函數[14]：

靜態隨機存取記憶體物理不可複製函數沿用靜態隨機存取記憶體(static random access memory, SRAM)單元從斷電到通電會初始化成邏輯 0 或是 1 的特性，整體架構與一般的靜態隨機存取記憶體一樣，靜態隨機存取記憶體單元如圖 2-8 所示，主要靠雜訊(noise)決定通電後的結果，這些元件可以分成偏向 0、偏向 1、不穩定三種特性，其中不穩定的元件在通電的時候不一定每次都會產生相同的值。挑戰值 c 當成靜態隨機存取記憶體的地址，而靜態隨機存取記憶體的輸出為響應值 r 。靜態隨機存取記憶體物理不可複製函數可以提供 2^N 組挑戰響應對，每組響應的位元數 M 為靜態隨機存取記憶體的位元數，屬於弱物理不可複製函數。

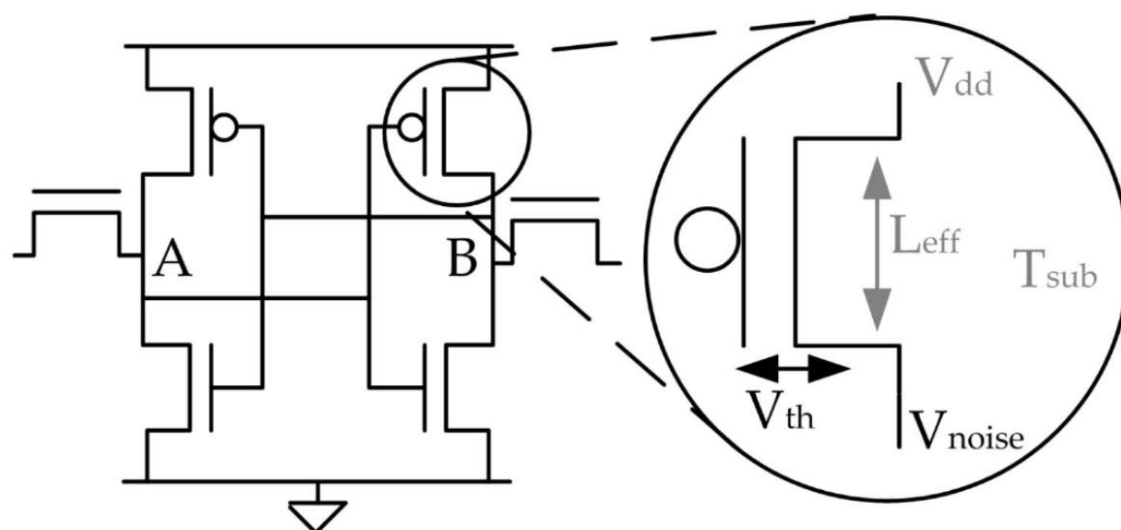


圖 2-8. 靜態隨機存取記憶體單元[14]

靜態隨機存取記憶體物理不可複製函數每一個單元可以提供一個秘密(secret)，所以每一個挑戰響應對的關聯性不高，此架構適合用來產生金鑰，可以根據需求調整記憶體的長度及寬度。

環形振盪器物理不可複製函數[15]：

環形振盪器物理不可複製函數利用多個相同環形振盪器產生頻率的差異來進行比較，產生出不同的響應值，整體架構如圖 2-9 所示。總共會有 K 組相同的環型震盪器，輸入用來控制多工器選擇兩組不同的震盪器頻率，計數器負責統計震盪器循環的次數，最後傳入比較器得到最終結果。此電路最多可以選擇 C_2^K 對不同的震盪器組，但是這些震盪器組之間可能會有關聯性，例如震盪器 A 比震盪器 B 快，震盪器 B 也比震盪器 C 快，可以由此推測震盪器 A 一定比震盪器 C 快。因為需要選擇兩組不同的震盪器，挑戰值 c 無法直接當成多工器的輸入，需要額外的電路來控制多工器，而比較器的輸出為響應值 r 。環形振盪器物理不可複製函數可以提供 $K(K-1)/2$ 組挑戰響應對，每組響應的位元數 M 為 1，挑戰值的位元數 N 根據額外的電路架構會有所不同，屬於弱物理不可複製函數。

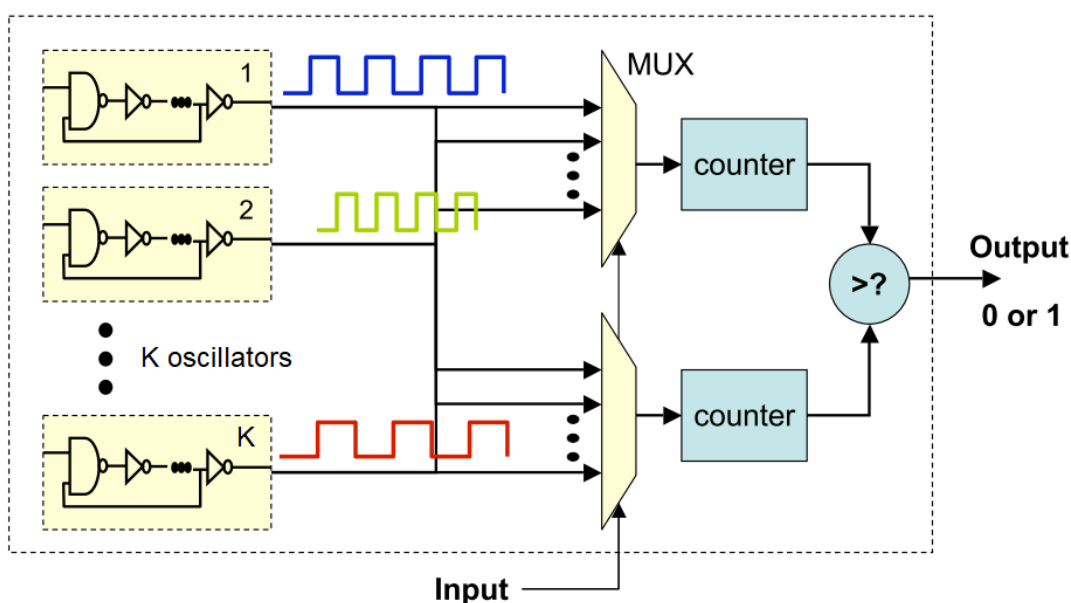


圖 2-9. 環形振盪器物理不可複製函數[15]

環形振盪器物理不可複製函數雖然採用比較的架構，但是環形振盪器沒有提供累加的效應，導致其成為弱物理不可複製函數，如果要讓響應值沒有關聯性，最多可以提供 K-1 組挑戰響應對。

2.2.2 模型攻擊

如 2.2.1 節所述，對於強物理不可複製函數，少量挑戰響應對的暴露可以建立精準的軟體模型，對於弱物理不可複製函數，因為挑戰響應對之間關聯性不高且數量較少，通常會取得所有挑戰響應對並建立表格。因為強物理不可複製函數具有大量的挑戰響應對，必須使用機器學習演算法訓練出軟體模型，大部分的強物理不可複製函數透過比較產生出二元的結果，因此許多線性二元分類的機器學習演算法都可以使用。

機器學習演算法透過訓練一個黑盒子，使其模型與預期的行為相符合，通常會將輸入特徵(input feature)乘以權重(weight)後再加總，並且經由一個非線性的激勵函數(activation function)產生預測的結果。在訓練時，會計算損失函數(loss function)並更新權重的值，直到到達設定的停止點。

感知器學習演算法(Perceptron Learning Algorithm, PLA)：

感知器學習演算法最早由文獻[22]提出，為早期的機器學習演算法，感知器學習演算法是用來建立線性二元分類的模型，將輸入特徵傳入感知器之後，經由擔任激勵函數的單位階躍函數(Heaviside step function)輸出 0 或是 1，代表物理不可複製函數的響應值，文獻[23]對感知器學習演算法應用在物理不可複製函數的方式有詳盡的介紹。

支援向量機(Support Vector Machines, SVMs)：

支援向量機的前身是廣義肖像演算法(Generalized Portrait algorithm)[24]，用來建立線性二元分類的模型，後來由同作者改進可以容忍訓練資料(training set)出現無法

完美線性二分的版本[25]，支援向量機透過訓練找到兩個可以將資料二分且平行的超平面，並且使兩者之間的距離最大，此距離是由離超平面最近的資料點所決定的，這些資料點也被稱作支援向量，而這兩個超平面正中間的超平面，則是用來分類輸入是屬於哪一群資料，經由擔任激勵函數的符號函數(sign function, sgn)輸出-1、0、1，其中-1、0代表物理不可複製函數的響應值為0，反之則為1，文獻[23]對支援向量機應用在物理不可複製函數的方式有詳盡的介紹。

邏輯迴歸(Logistic Regression, LR)：

邏輯迴歸是統計學中其中一個迴歸分析的方式，不同於一般的線性迴歸根據輸入預測輸出的數值，邏輯迴歸根據輸入預測輸出的機率，屬於線性二元分類的機率模型，將輸入特徵傳入邏輯迴歸後，經由擔任激勵函數的邏輯函數(logistic sigmoid function)輸出分類為1的機率，超過50%則代表輸出為1，反之則為0，文獻[23]對邏輯迴歸應用在物理不可複製函數的方式有詳盡的介紹。

演化策略(Evolution Strategy, ES)：

演化策略是根據自然演化的機制發展而來的一種優化演算法，通過重複的變異並選擇較佳的子代，與前面三種機器學習方式不同，演化策略屬於非監督式學習(unsupervised learning)，前三種以優化損失函數為目標，並且更新權重的值，而演化策略透過損失函數得到不同權重的合適度(fitness)，選擇合適度最佳的權重並以此為下一次變異的父代，文獻[17]將演化策略應用在物理不可複製函數上。

2.2.3 旁路攻擊

為了防止駭客透過取得物理不可複製函數的挑戰響應對，設計者通常會使用額外的數位邏輯來保護挑戰響應對，控制物理不可複製函數(controlled PUF)[26]為其中之一

個基礎的防護方式，如圖 2-10 所示，在物理不可複製函數的挑戰前與響應後加入雜湊函數(hash function)，使真正的挑戰響應對隱藏在晶片內，讓模型攻擊無法使用。

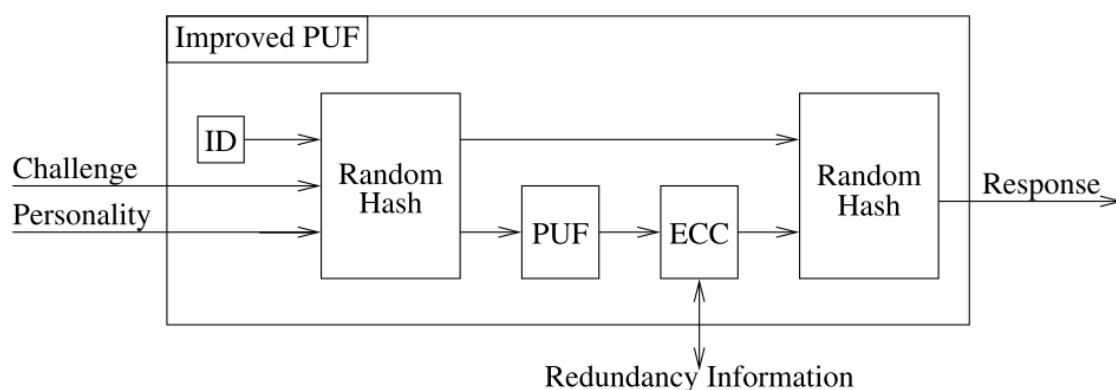


圖 2-10. 控制物理不可複製函數[26]

與非揮發性記憶體遇到的問題相同，近幾年發展出許多種針對弱物理不可複製函數的旁路攻擊方式，或是針對強物理不可複製函數的混和旁路和模型攻擊方式[8]，這些攻擊方式可以分成被動攻擊(passive attack)、主動攻擊(active attack)以及半侵入式攻擊(semi-invasive attack)，以下將針對這些攻擊方式作介紹。

被動攻擊(passive attack)：

被動攻擊主要以不影響物理不可複製函數的運作方式取得洩漏的資訊，通常藉由觀察電路在運作時產生的資訊洩漏來訓練模型，最常被使用的方式是功率旁路攻擊(power side channel attack)以及時間旁路攻擊(timing side channel attack)，互斥或仲裁器物理不可複製函數與輕量級安全物理不可複製函數在文獻[19]成功被攻擊，此文獻使用兩種旁路攻擊方式都破解成功，功率旁路攻擊主要利用互斥或閘(XOR gates)被響應值啟用的數量與增加的互斥或閘功率消耗成線性關係，藉由量測物理不可複製函數的功率消耗可以得到響應值為 1 的數量；時間旁路攻擊利用每一個互斥或閘被響應值啟用的時間不同，來得到響應值為 1 的數量，這兩種方式只要等到合適的挑戰響應對出現即可記錄下來供訓練使用。

主動攻擊(active attack)：

主動攻擊主要以影響物理不可複製函數的運作方式，藉由洩漏的錯誤資訊來訓練模型，主動攻擊可以分成錯誤攻擊(fault attack)以及輔助資料操縱攻擊(helper data manipulation attack)，錯誤攻擊以改變電路運作的電壓或溫度，使用電路產生錯誤的資訊進行機器學習訓練，文獻[27]在物理不可複製函數運作時改變一小段時間的電壓，使特定的挑戰響應對增加出錯的機率，同時軟體模型也預測出錯的挑戰響應對，如果實際與預測出錯的挑戰響應對關聯性越高，代表模型的準確率越高；輔助資料操縱攻擊為一種常見的物理不可複製函數攻擊方式，因為大部分物理不可複製函數的可靠度並非百分之百，如果要當成加密演算法的金鑰，需要確保每次的響應值不能出錯，設計者通常會加入錯誤更正碼(error correction code, ECC)或是模糊提取器(fuzzy extractor, FE)[28]的模組，這類模組需要輔助資料來協助更正錯誤的數值，因此常常成為安全漏洞的來源，文獻[29]提出兩種輔助資料的攻擊方式，可以復原出物理不可複製函數的響應值，文獻[30]利用不同環境下產生的輔助資料取得不穩定的響應值，再利用文獻[27]提出的方式訓練軟體模型。

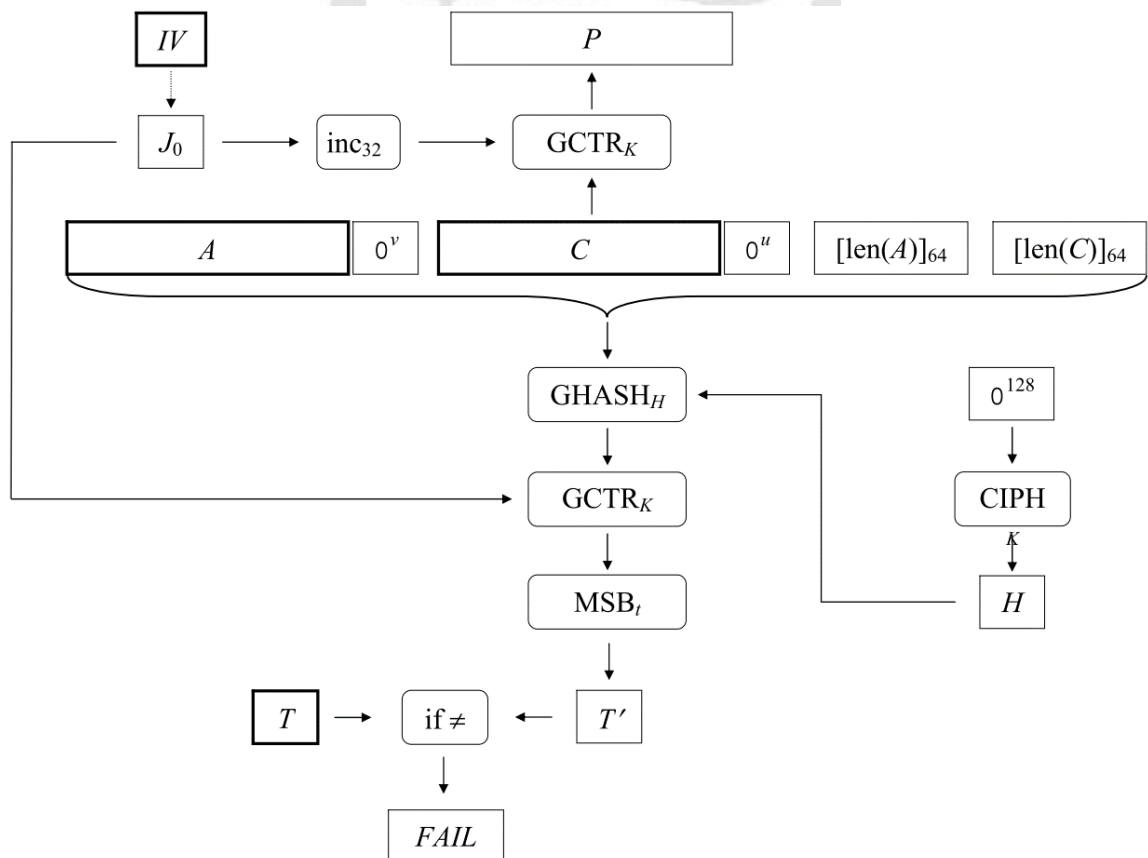
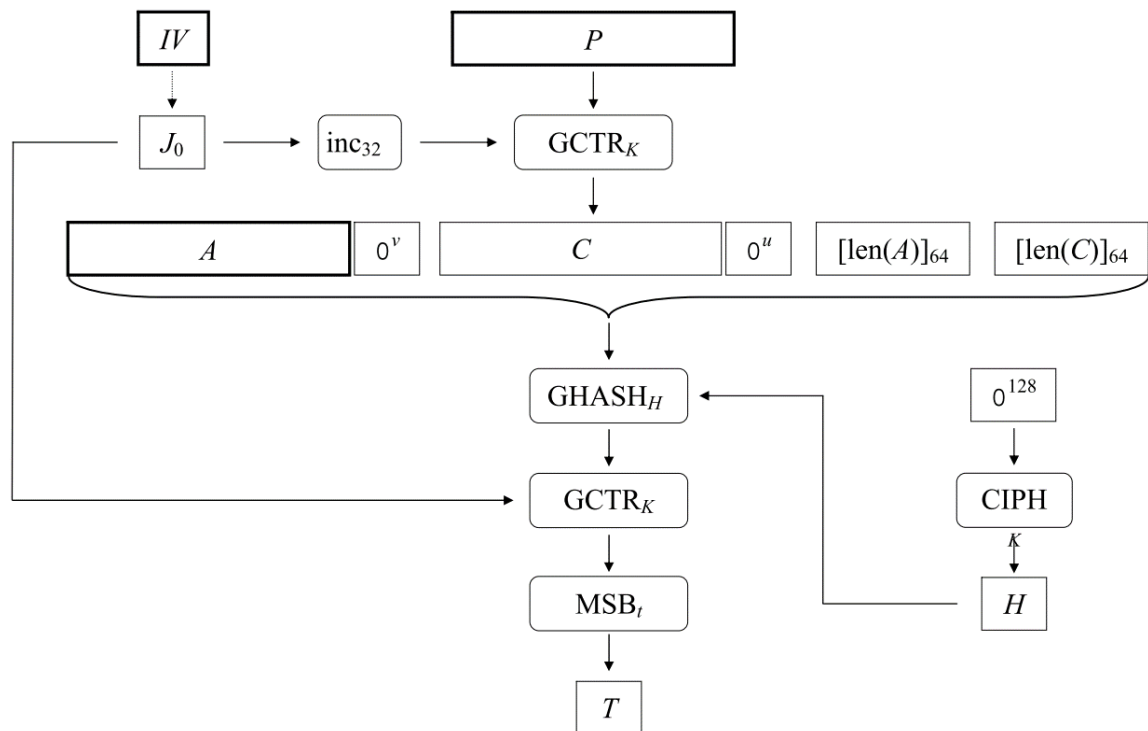
半侵入式攻擊：

半侵入式攻擊以拆除晶片的封裝，並且在不影響電路功能的前提下取得洩漏資訊，目前成功的半侵入式攻擊分為光子分析攻擊(photonic attack)和電磁分析攻擊(Electromagnetic attack)，光子分析攻擊通過觀察電路的光子發射，來分析電路的運作情形，文獻[31]使用雷射光刺激(laser stimulation, LS)取得靜態隨機存取記憶體物理不可複製函數單元的狀態，文獻[32]透過光子發射的情形，來分析仲裁器物理不可複製函數不同路徑的延遲時間並取得響應值；電磁分析攻擊透過觀察晶片不同區域的電磁輻射，取得該區域的頻譜後進行分析，文獻[33]透過分析環形振盪器物理不可複製函數的頻譜，回推出每一個環形振盪器的頻率，藉此得到環形振盪器物理不可複製函數的模型。

2.3 進階加密標準

進階加密標準[34]是美國國家標準暨技術研究院從 1997 年開始發展的加密演算法，目的是保護政府的機密資料，最後由 Rijndael 加密法勝出，在 2001 年成為進階加密標準。進階加密標準是一種對稱式加密演算法(symmetric key algorithm)，其加密與解密使用的金鑰相同，加密區塊長度為 128 位元、金鑰長度可以為 128、192 或 256 位元。在加密開始前，金鑰會先進行 Rijndael 密鑰生成方案(Rijndael key schedule)，將金鑰擴展成每一輪要使用的子金鑰，接下來依據金鑰長度進行 10 輪以上的 AddRoundKey、SubBytes、ShiftRows、MixColumns 運算即可加密完成；解密流程與加密流程類似，只有後面四種運算的順序不同而已。目前不存在有效的方式破解進階加密標準，使用超級電腦進行暴力破解法(brute-force attack)[35]也需要遠超過千兆年才能搜尋完所有可能的 128 位元金鑰，192 和 256 位元的金鑰可以提供更高的安全性。

根據美國國家標準暨技術研究院的建議[36]，可以使用以下五種區塊加密法(block cipher)的工作模式(mode of operation)：電子密碼本(Electric Codebook, ECB)、密碼塊連結(Cipher Block Chaining, CBC)、密文回饋(Cipher Feedback, CFB)、輸出回饋(Output Feedback, OFB)以及計數器(Counter, CTR)，配合美國國家標準暨技術研究院公布在聯邦資訊處理標準(Federal Information Processing Standards, FIPS)的對稱式金鑰區塊加密法來保護敏感資料，進階加密標準為現在經常被使用的一種區塊加密法。因為這些工作模式沒有提供認證的功能，美國國家標準暨技術研究院後來也推出數種配合區塊加密法的工作與認證模式，其中伽羅瓦/計數器模式(Galois/Counter Mode, GCM)[37]為本論文使用的模式，伽羅瓦/計數器模式沿用了計數器的加密與解密方式，並且使用伽羅瓦訊息驗證碼(Galois Message Authentication Code, GMAC)對額外認證資料(additional authenticated data, AAD)與密文(ciphertext)進行認證，其中加密與解密的流程分別如圖 2-11 與圖 2-12 所示。



伽羅瓦/計數器模式目前並沒有太大的安全性問題[38]，除了繼承了計數器模式的缺點，當兩組不同的明文使用同一組金鑰以及初始向量(initialization vector, IV)進行加密，兩組密文進行互斥或運算的結果會等同於兩組明文進行互斥或運算，因此明文洩漏的機率會大幅提升，使用上必須避免此種情況的發生。





第 3 章 相關文獻探討

本章節將探討物理不可複製函數及裝置安全的相關文獻，在 3.1 節對物理不可複製函數可能受到攻擊的方式做討論，在 3.2 節對裝置安全開機的架構及流程做討論。

3.1 攻擊物理不可複製函數

3.1.1 延遲加法模型

在相關文獻(CCPE'04)[20]中，作者提出延遲加法模型(additive delay model)來建立仲裁器物理不可複製函數的模型，並且成功利用模型攻擊模擬出仲裁器物理不可複製函數的挑戰響應對。

仲裁器物理不可複製函數的架構如圖 2-3 所示，同一個挑戰位元會控制一對多工器，可以將每一對多工器視為有四種不同延遲的交換器如圖 3-1(a)所示，當挑戰位元為 0 時，交換器會選擇直行的 a 、 b 兩條路徑，反之則會選擇交錯的 c 、 d 兩條路徑；此交換器可以簡化成另外一種模型如圖 3-1(b)所示，延遲可以被分成共同延遲 $u = (a + b + c + d)/4$ 、直行與交錯的延遲差 $v = (a + b - c - d)/4$ 、從上面與下面開始的延遲差 $x = (a - b + c - d)/4$ 、從上面與下面結束的延遲差 $y = (a - b - c + d)/4$ ，將所有交換器連接在一起的模型如圖 3-1(c)所示，其中 x 與前一級的 y 合併， u 和 v 的值對兩條路徑一樣，所以可以移到模型的最前方，並且每一級的 u 可以合併在一起。

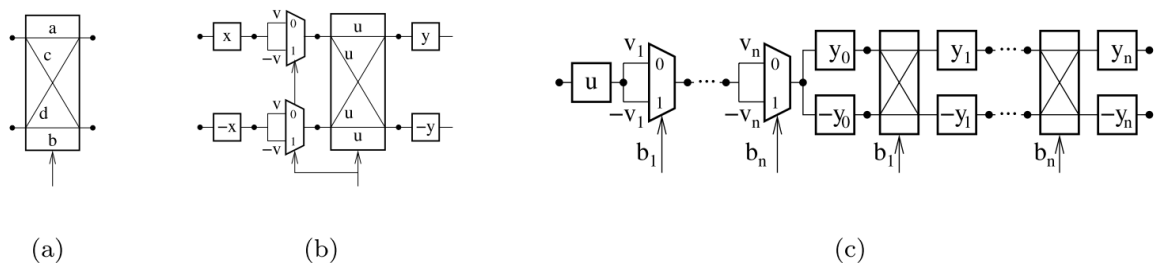


圖 3-1. 仲裁器物理不可複製函數(a)簡化前和(b)簡化後的交換器模型，以及(c)整體

電路模型[20]

模擬 n 級交換器的延遲時間原本需要 $4n$ 個參數，經由此模型可以縮減成 $2n + 2$ 個參數，如果只需要知道仲裁器的結果，只需要 $n + 1$ 個參數。一條路徑的延遲可用式(3.1)表示，其中奇偶校驗(parity)向量 $p_i = b_i \oplus \cdots \oplus b_n$ ，代表從最後一級到該級的路徑切換次數， $\oplus$ 代表互斥或，另一條路徑的延遲也類似，只有 y_i 變成負的，將兩條路徑相減，其正負號代表響應值的狀態。

$$u + \sum_{i=1}^n (-1)^{b_i} v_i + \sum_{i=0}^n (-1)^{p_i} y_i \quad (3.1)$$

此文獻在現場可程式化邏輯閘陣列(Field Programmable Gate Array, FPGA)上實作仲裁器物理不可複製函數，使用感知器學習演算法以及量測的 90000 組挑戰響應對來訓練模型，並使用另外的 100000 組挑戰響應對來驗證模型的正確性，其錯誤率為 0.61%。作者提出兩種可能的方式來對抗延遲加法模型，第一種是前饋式仲裁器物理不可複製函數，目前已被文獻[7]破解，另一種方式是加入變數延遲緩衝器(variable-delay buffer)，此種方式在每一個交換器之間加入緩衝器，但是緩衝器的延遲時間交由另外一條路徑的狀態所決定，為電路加入了非線性的延遲，加法延遲模型無法有效地模擬此種情況。

3.1.2 功耗分析旁路攻擊

在相關文獻(IACR'14)[27]中，作者提出使用功耗分析旁路攻擊控制物理不可複製函數的方式，成功利用功率消耗以及模型響應值的相關係數訓練軟體模型。

控制物理不可複製函數的架構如圖 2-10 所示，因為物理不可複製函數的響應值會先經過雜湊函數的運算，導致駭客無法直接取得原本的響應值，但是因為仲裁器物理不可複製函數一次只會產生一個位元的響應值，在控制物理不可複製函數內需要加入一組位移暫存器來儲存響應值，作者量測仲裁器物理不可複製函數的響應值儲存到暫存器所消耗的功率如圖 3-2 所示，不同的響應值會影響儲存時的功率消耗，也發現模型準確率越高，其響應值與功耗的相關係數越高如圖 3-3 所示。

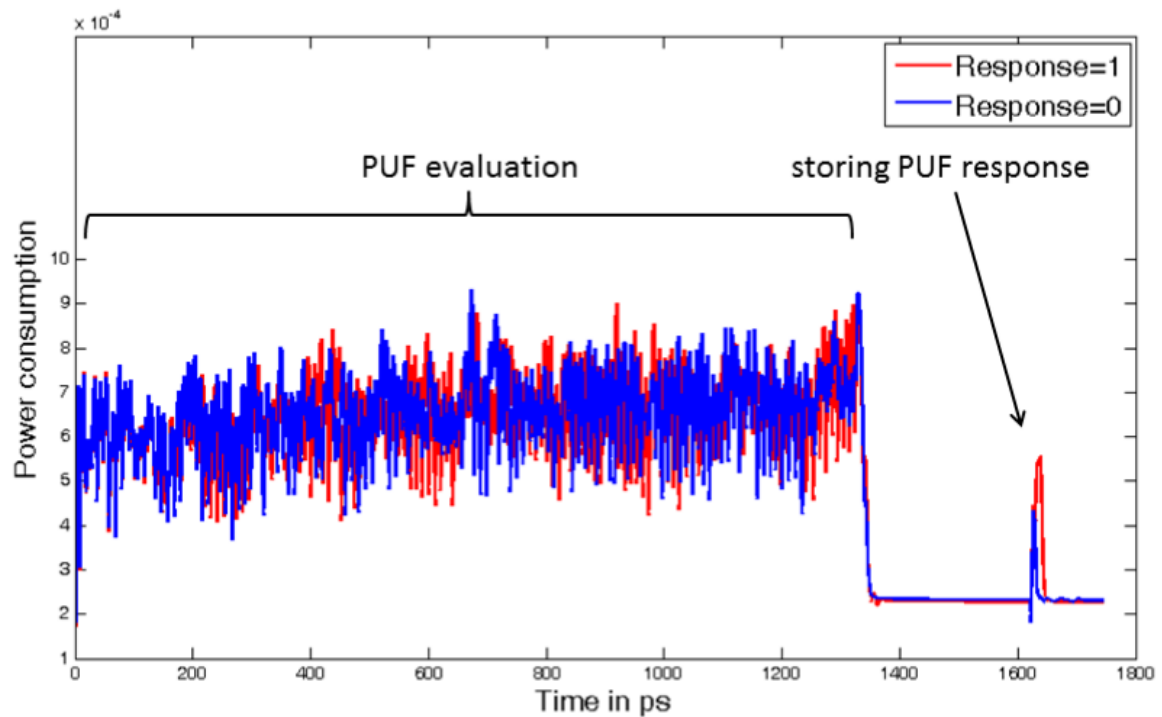


圖 3-2. 仲裁器物理不可複製函數的響應值儲存到暫存器的功率消耗[27]

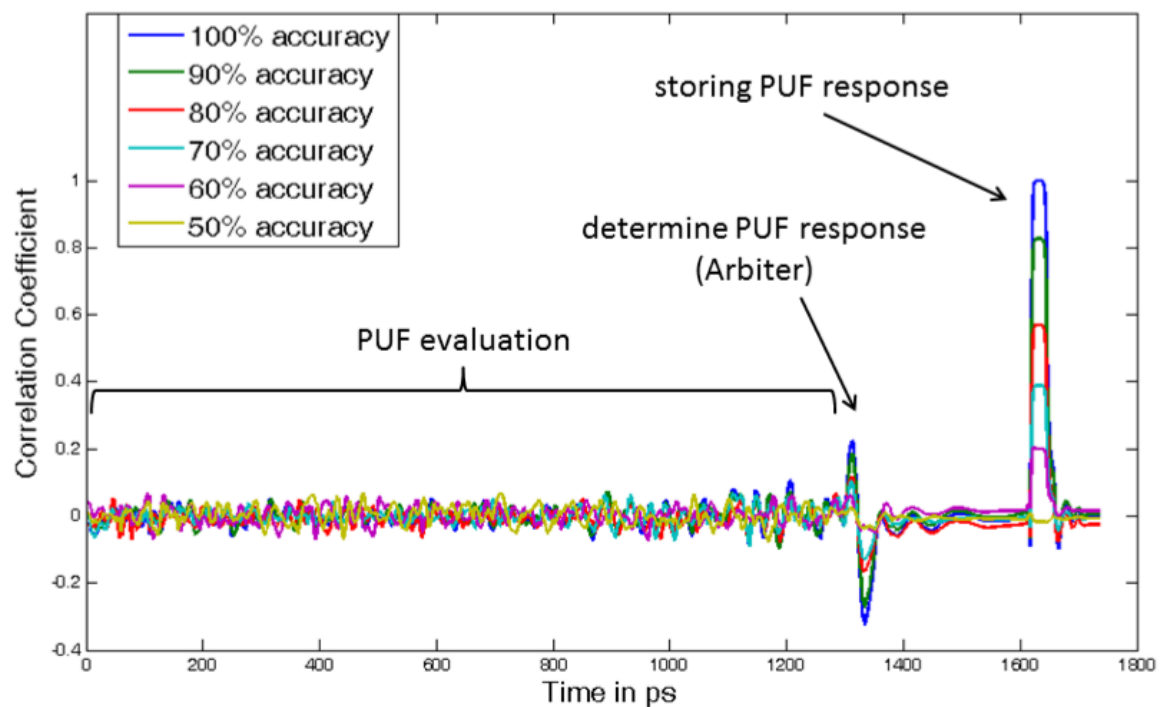


圖 3-3. 仲裁器物理不可複製函數模型響應值與實際功耗的相關係數[27]

在無雜訊的環境下，可以直接從功率記錄(power trace)找出響應值，但是實際上功率會存在一些不同來源的雜訊，假設雜訊的來源是互相獨立而且數值是可以疊加的，整體雜訊量可以視為高斯分布(Gaussian distribution)，其中物理和量測雜訊可以經由多次量測來平均，演算法(algorithmic)和模型匹配(model matching)雜訊通常是固定的，無法經由量測來平均。假設雜訊的平均值為 μ 、標準差為 σ ，其值可以寫成 $N(\mu, \sigma^2)$ ，因為平均值 μ 不會影響相關係數的結果，可以將雜訊改寫成 $N(0, \sigma^2)$ 。

作者建立三種不同的功率模型來建立一 80 位元物理不可複製函數的功率消耗：1 位元漢明重量(1-bit Hamming weight)、1 位元漢明距離(1-bit Hamming distance)、80 位元漢明距離(80-bit Hamming distance)功率模型，並發現在有雜訊的狀況下，80 位元漢明距離功率模型可以達到最高的準確度，表 3-1 代表 1 位元漢明重量和 80 位元漢明距離功率模型在不同雜訊下所需要的挑戰數量及其準確率，使用的機器學習演算法為自適應共變異數矩陣演化策略(covariance matrix adaptation evolution strategy, CMA-ES)。

表 3-1. 不同功率模型在不同雜訊下需要的挑戰數量及其準確率[27]

1-bit Hamming Weight Power Model			80-bit Hamming Distance Power Model		
Noise Level	Challenges	Accuracy	Noise Level	Challenges	Accuracy
$N(0, 25)$	80k	89%	$N(0, 25)$	30k	97%
$N(0, 125)$	450k	90%	$N(0, 250)$	50k	95%
$N(0, 250)$	750k	89%	$N(0, 2.5k)$	150k	93%
$N(0, 1250)$	4,000k	87%	$N(0, 25k)$	1,000k	93.6%
$N(0, 2500)$	7,500k	88%	$N(0, 250k)$	10,000k	88.2%

3.2 安全開機流程

3.2.1 自我認證之安全開機

在相關文獻(HOST'18)[39]中，作者提出針對 Xilinx 的 Zynq 系列現場可程式化邏輯閘陣列的自我認證之安全開機(self-authentication secure boot, SASB)架構，保護使用者的位元流(bitstream)不被逆向工程(reversed engineering)分析。

Xilinx 提出的安全開機流程如圖 3-4 所示，開機唯讀記憶體的程式讀取儲存於外部非揮發性記憶體的第一階段開機讀取器(first stage boot loader, FSBL)並儲存於動態隨機存取記憶體(dynamic random access memory, DRAM)；第一階段開機讀取器解密並驗證位元流的完整性，將位元流燒錄在邏輯閘陣列，然後讀取第二階段開機讀取器(U-boot)到動態隨機存取記憶體；第二階段開機讀取器讀取作業系統或是裸金屬(bare metal)程式及相關的檔案。Xilinx 使用安全雜湊演算法 2(SHA-2)計算雜湊值並嵌入位元流之中，然後使用進階加密標準密碼塊連結模式來加密位元流，解密的時候會再計算一次雜湊值並與嵌入的雜湊值做比較，不同的話則會取消開機；Xilinx 也使用非對稱式密碼學(asymmetric cryptography)來認證開機程式或檔案。

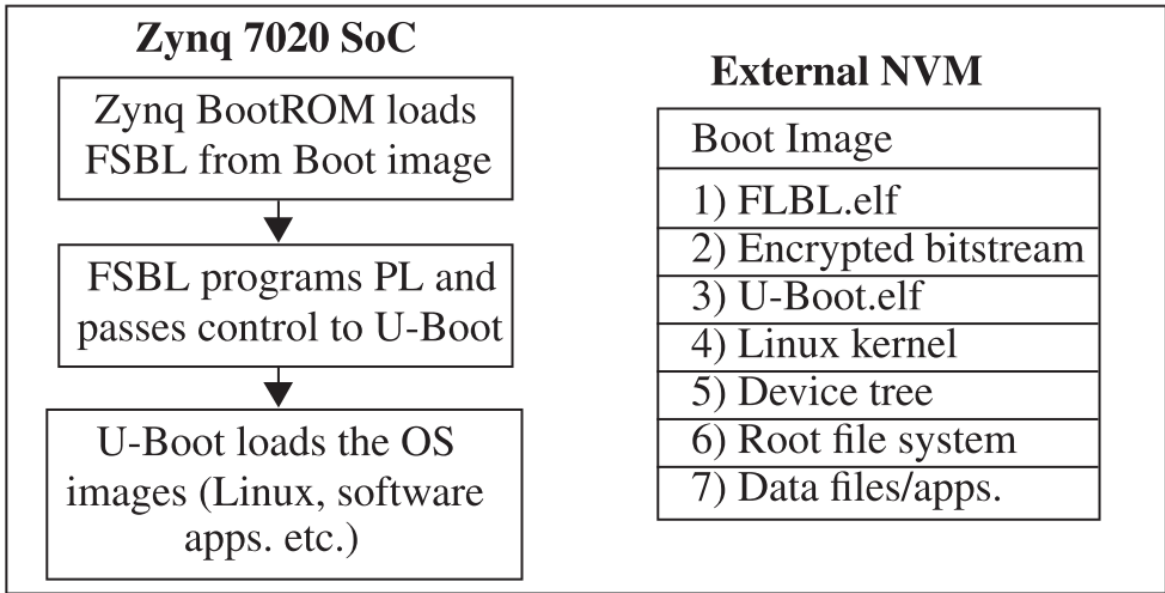


圖 3-4. Xilinx 安全開機流程[39]

因為 Xilinx 提出的安全開機流程主要使用儲存於非揮發性記憶體的金鑰，作者提出的安全開機流程不會使用到 Xilinx 提供的安全功能，其流程圖如圖 3-5 所示，一開始執行第一階段開機讀取器將安全開機架構的位元流燒錄在邏輯開陣列，安全開機架構會使用內部的物理不可複製函數及外部的輔助資料產生解密的金鑰，並解密應用位元流、第二階段開機讀取器、作業系統或應用等資料，在解密初期會先確認金鑰的完整性，如果檢查失敗則取消開機，之後開機流程與原本的類似。此文獻使用一種量測電路延遲的物理不可複製函數[40]，此物理不可複製函數可以用來量測其他電路的延遲時間，並用來產生響應值，被量測的電路會有兩種模式，第一種是電路原本的功能，第二種是發射接收模式(launch-capture mode)，此模式讓物理不可複製函數可以送入兩組不同的測試序列，並將量測出來的延遲數值記錄在內部記憶體內，用來產生響應值。

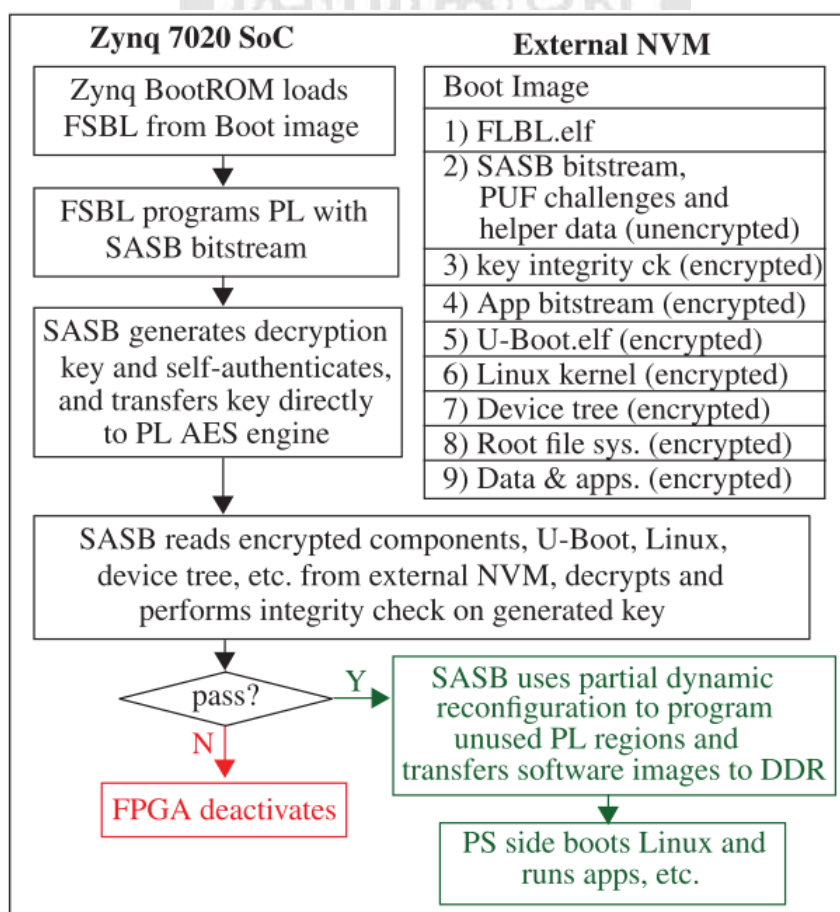


圖 3-5. 自我認證之安全開機流程[39]

作者提出了攻擊模型(attack model)如所示，對手的目標是偷取進階加密標準的金鑰，也就是物理不可複製函數的響應值，第一條路徑(A₁)是更改安全開機架構的電路來偷取金鑰，因為物理不可複製函數產生的響應值會儲存在金鑰暫存器(key registers)，所以對手可以在暫存器到進階加密標準的路徑上插入扇出(fan-out)的導線，將金鑰直接送到現場可程式化邏輯閘陣列的輸出腳位，但因為現場可程式化邏輯閘陣列的扇出需要交換器區塊(switch box)來達成，而扇出的導線數量是有限制的(每一個交換器區塊只能有 32 個扇出導線)，作者利用這個特性將金鑰暫存器到進階加密標準路徑上所有的多餘的扇出都加入物理不可複製函數的量測範圍，只要有任何一條扇出的導線被挪作他用都會導致物理不可複製函數的響應值出現很大的不同，因此第一條路徑是安全的；第二條路徑(A₂)是在應用邏輯端插入硬體木馬(hardware Trojan)來偷取金鑰，此路徑有一種有效的防治方式，在產生金鑰之前先使用有限狀態機(finite state machine)寫入一個空白的位元流，此空白位元流的目的是將應用邏輯端所有元件都設定成不使用，所有的硬體木馬都會被清除，但是駭客可能會修改安全開機架構將有限狀態機移除，防治的方式為讓物理不可複製函數也量測有限狀態機的延遲時間，如果有任何電路上的修改都會導致最後的金鑰出錯。

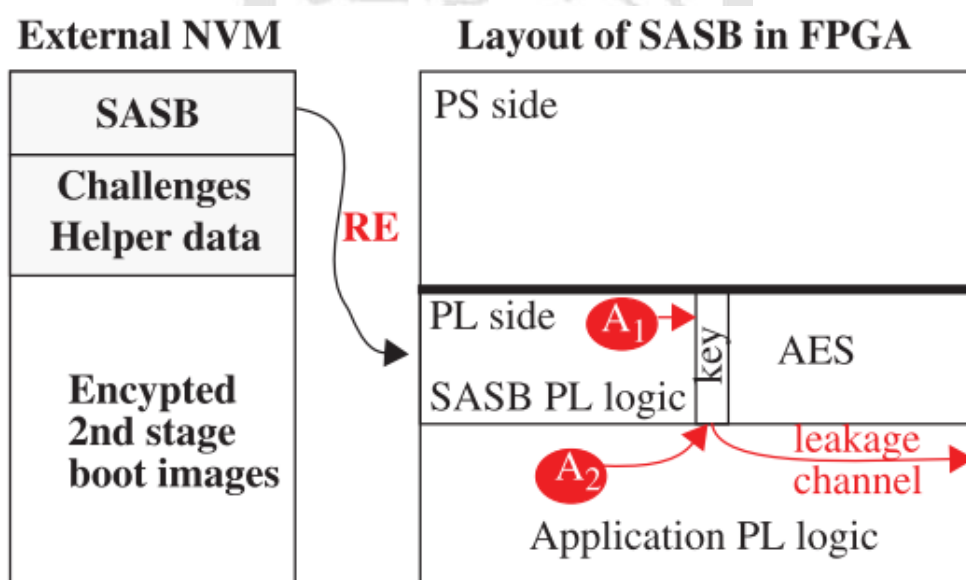


圖 3-6. 自我認證之安全開機架構的攻擊模型[39]

3.2.2 輕量級安全開機架構

在相關文獻[41]中，作者提出針對 RISC-V 系統單晶片(system-on-chip, SoC)的輕量級安全開機架構(lightweight secure-boot architecture)，從開機階段確保裝置的安全性。

作者提出的系統架構圖如圖 3-7 所示，此架構有兩顆 RISC-V Rocket 核心、兩級快取、以及一些記憶體及周邊裝置，主要用來執行 Linux 作業系統，內部有幾個提供安全功能的元件：第一個是金鑰管理元件(key management unit, KMU)，內含儲存非對稱式加密演算法公鑰的電子熔斷器(fuse)，以及用來產生對稱式加密演算法金鑰的物理不可複製函數；第二個是程式碼認證元件(code authentication unit, CAU)，內含橢圓曲線數位簽章演算法(elliptic curve digital signature algorithm, ECDSA)用來解密，以及第三代安全雜湊演算法(secure hash function 3, SHA-3)用來驗證程式的完整性，配合開機流程元件(boot sequencer)來達成安全開機；第三個是安全除錯(secure debug)，使用物理不可複製函數保護該元件，可以防治金鑰萃取(key extraction)、非法除錯(illicit debugging)、探測(probing)及旁路攻擊(side channel attack, SCA)；第四個是安全執行環境(trusted execution environment, TEE)，隔離的執行環境用來執行受保護的應用，可以防治軟體利用(software exploitation)、特權升級(privilege escalation)及殭屍網路註冊(botnet enrolling)；第五個是可信任的晶片外記憶體(trusted off-chip memory)，使用可信任的晶片外記憶體可以防治旁路攻擊、探測及金鑰萃取等攻擊。此相關文獻主要強調金鑰管理元件及程式碼認證元件在安全開機上的應用。

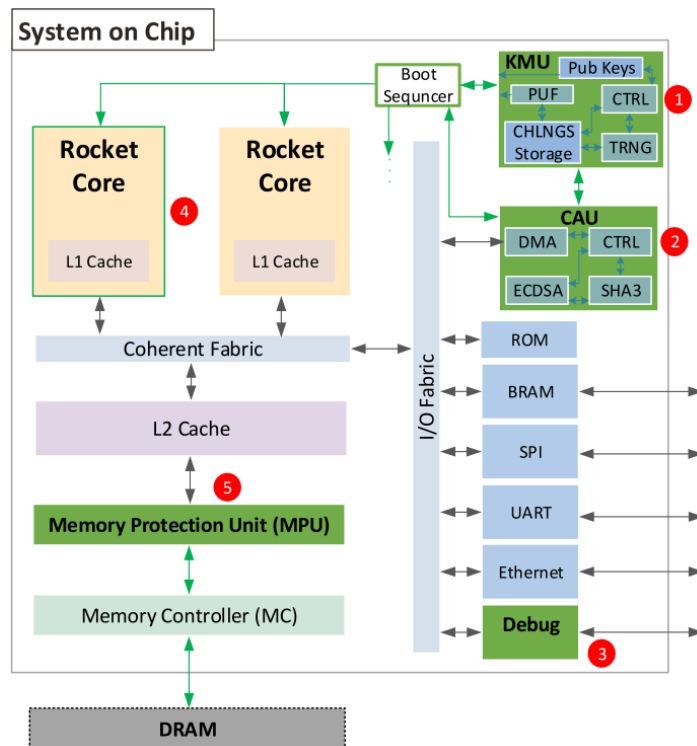


圖 3-7. 輕量級安全開機架構[41]

作者使用信任鏈的流程來確保系統的完整性(integrity)與真實性(authenticity)，信任鏈的流程如圖 3-8 所示，除了第一階段開機讀取器儲存在晶片的唯讀記憶體內，其他程式碼都會儲存在晶片外的非揮發性記憶體內，程式碼認證元件負責驗證開機流程每一個階段程式碼的完整性，這些程式碼最後都會附加一組經由橢圓曲線數位簽章演算法加密的簽章(signature)，如果程式碼經由第三代安全雜湊演算法運算之後的結果與解密後的簽章不符合，代表程式碼有可能被竄改，開機流程因此終止。

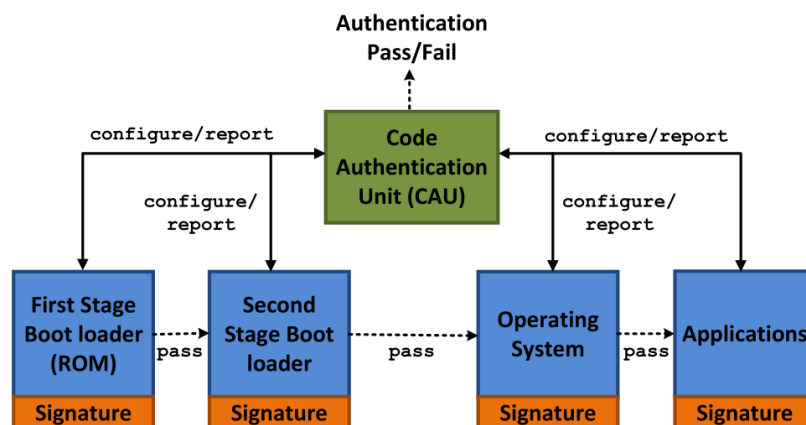


圖 3-8. 程式碼認證元件認證每一階段程式碼的流程[41]

一般使用軟體的安全開機流程如圖 3-9(a)所示，RISC-V 核心需要執行加密演算法來認證每一個階段的程式，整體的執行速度會因此下降，而相關文獻使用硬體的开機流程元件來主導整個開機流程，配合金鑰管理元件及程式碼認證元件來達成安全開機。

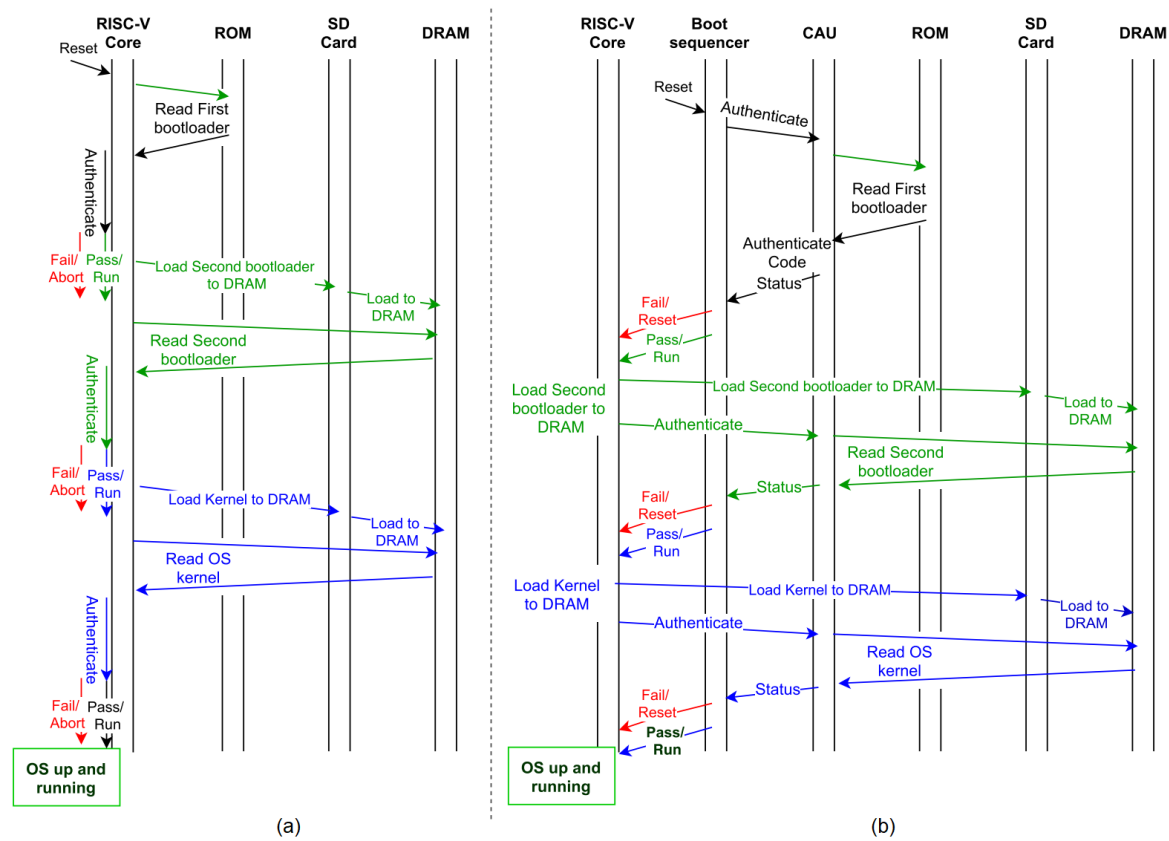


圖 3-9. 安全開機流程，(a)為一般軟體認證的開機流程，(b)為相關文獻提出的硬體認證開機流程[41]

3.3 相關文獻總結

- 前述的相關文獻可以做以下幾點總結，相關文獻的比較如表 3-2 所示：
- 相關文獻[20]提出延遲加法模型來建立仲裁器物理不可複製函數的模型，並且在取得足夠數量挑戰響應對的情況下，使用感知器學習演算法成功訓練出模型。

- b. 相關文獻[27]提出使用功耗分析旁路攻擊和模型攻擊來建立控制物理不可複製函數的模型，因為控制物理不可複製函數並不會直接洩漏出內部物理不可複製函數的挑戰響應對，但是功耗與內部響應值為正相關，使用自適應共變異數矩陣演化策略及兩者的相關係數成功訓練出模型。
- c. 相關文獻[39]提出現場可程式化邏輯閘陣列的自我認證之安全開機架構取代 Xilinx 原本的開機流程，保護應用位元流、開機韌體、作業系統及應用程式，使用進階加密標準及物理不可複製函數加密資料，硬體的自我認證可以防止硬體木馬偷取金鑰，韌體及軟體進行認證只有使用安全雜湊函數，而非訊息驗證碼。
- d. 相關文獻[41]提出 RISC-V 系統單晶片的安全開機流程，使用程式認證元件、金鑰管理元件及開機流程元件對儲存在晶片上及晶片外的開機韌體、作業系統及應用程式進行認證，作者使用硬體的開機流程元件雖然對效能有所提升，但是缺少可更改的彈性，同時也未對晶片外的資料進行加密。

表 3-2. 相關文獻比較

	Related Work (I)	Related Work (II)	Related Work (III)	Related Work (IV)
Publication	CCPE'04	IACR'14	HOST'18	ISQED'19
Position	Attacker	Attacker	Defender	Defender
Target	Arbiter PUF	Attack controlled PUF	Application bitstream of FPGA	RISC-V SoC
Attack Method	Use Perceptron Learning Algorithm to train PUF model by CRPs	Use CMA-ES to train PUF model by challenges and power consumption of shift registers	1. Fanout-branch insertion 2. Key-snooping	Key Extraction, Illicit Debugging, Probing, Side Channel Attacks, Software Exploitation, Privilege Escalation and Botnet Enrolling
Main Idea	Use additive delay model to reduce model parameters	Use power consumption to get state of shift registers	1. Use PUF responses as key to encrypt bitstream 2. Prevent adversary from accessing PUF responses	1. Use public key cryptography to verify integrity of code 2. Use PUF responses as key to protect components
Accuracy	99.39%	≥ 88.2%	N/A	N/A
Countermeasure	Feed Forward PUF (broken at [7])	N/A	1. Fanout-blocking 2. Blanking bitstream	Chain of trust



第 4 章 具有硬體和韌體安全性的 RISC-V 系統

如 1.2 節所述，在資源有限的物聯網系統上使用非揮發性記憶體建立保護系統的機制會造成成本提高，使用物理不可複製函數比非揮發性記憶體有更多的優勢，但是因為物理不可複製函數容易遭受模型攻擊，同時也不能免疫旁路攻擊，所以建立保護物理不可複製函數的機制是必要的。在這章節中，首先會在 4.1 節介紹平台的環境以及系統架構，在 4.2 節介紹保護韌體的機制及安全開機流程，在 4.3 節介紹對手的攻擊模型。

4.1 平台之環境與架構

本平台的架構如圖 4-1 所示，具有兩個 RISC-V 三階管線(3-stage pipeline)微處理器核心，其中使用者核心(user core)負責一般性資料處理及運行作業系統或應用程式，特權核心(privilege core)負責安全開機的流程以及可信任程式的執行，記憶體保護元件(memory protection unit, MPU)只有特權核心可以存取，可以管理使用者核心對周邊元件的存取權，匯流排為 ARM 的精簡版進階高效能匯流排(AHB-Lite)組成的匯流排矩陣(bus matrix)，隨機存取記憶體(RAM)為程式碼與資料共用，唯讀記憶體儲存第一階開機讀取器，安全模組(secure module)內含密碼學演算法加速器以及物理不可複製函數，詳細架構將在 4.1.2 節介紹，橋接器負責連接進階高效能匯流排與進階周邊匯流排(APB)，同時還有序列周邊介面(SPI)、非同步收發傳輸器(UART)及通用輸入/輸出(GPIO)負責與外界溝通。

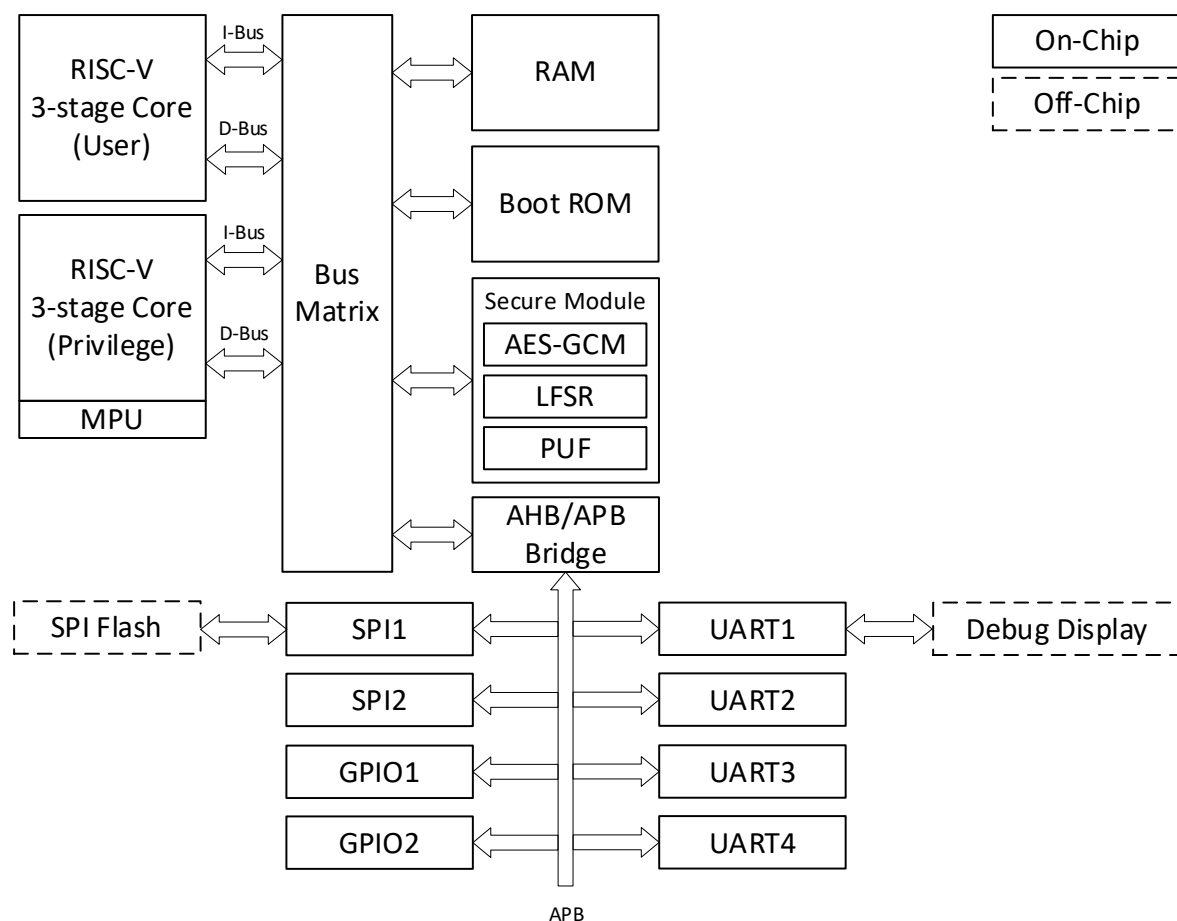


圖 4-1. 具硬體和軟體安全性的 RISC-V 系統架構

4.1.1 微處理器架構

本平台使用 Syntacore 的開源半導體矽智財微處理器核心 SCR1[42]，此為可配置核心，可以調整 RISC-V 擴充指令集的種類以及管線的級數，本平台使用的配置為 32 位元的基礎整數指令集(base integer instruction set, “RV32I”)及擴充的整數乘除法指令集(integer multiplication and division, “M”)和壓縮指令集(compressed instructions, “C”)，管線的長度為 3 級，特權等級只有機器模式(machine mode, M-mode)，其架構如圖 4-2 所示。兩顆核心架構相同，但是在匯流排上擁有的權限不同，周邊裝置可以拒絕權限不夠的核心存取。

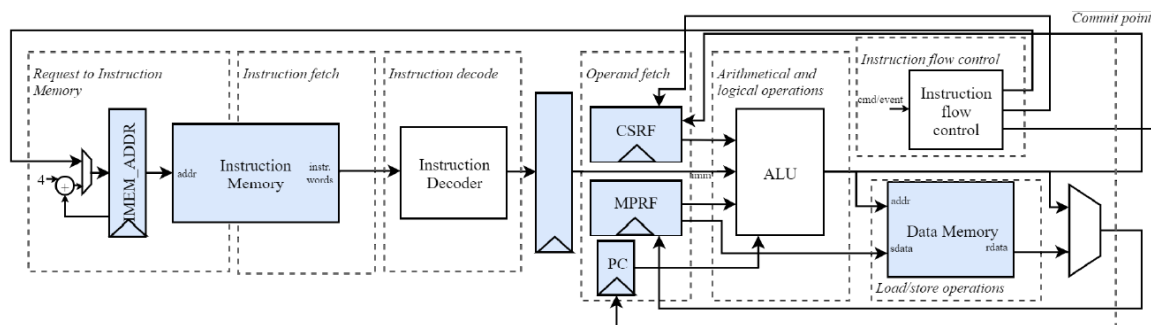


圖 4-2. SCR1 三階管線處理器架構[43]

4.1.2 安全模組架構

本平台的安全模組是由進階加密標準—伽羅瓦/計數器模式及仲裁器物理不可複製函數組成，仲裁器物理不可複製函數用來提供進階加密標準的金鑰，因為仲裁器物理不可複製函數一次只會產生一個位元的響應值，我們採用線性反饋移位暫存器 (linear feedback shift register, LFSR) 讓輸入的挑戰值產生不同的子挑戰值(sub-challenges)，本論文使用 128 位元的進階加密標準，所以需要執行物理不可複製函數 128 次來產生 128 位元的金鑰。加密流程如圖 4-3 所示，進階加密標準使用物理不可複製函數產生的金鑰產生雜湊函式的子金鑰(hash subkey, H)，然後加密初始向量(IV)及內部計數器，將加密的結果與明文(plain text)做互斥或得到密文(plain text)，最後將密文送入 GHASH 雜湊函式得到認證標籤(tag)；解密流程如圖 4-4 所示，與加密流程類似，差別在於使用初始向量及計數器加密的結果與密文做互斥或得到明文，最後認證標籤會與待確認的標籤(to be checked tag, TBC tag)進行比較，輸出認證通過或是失敗的訊號。

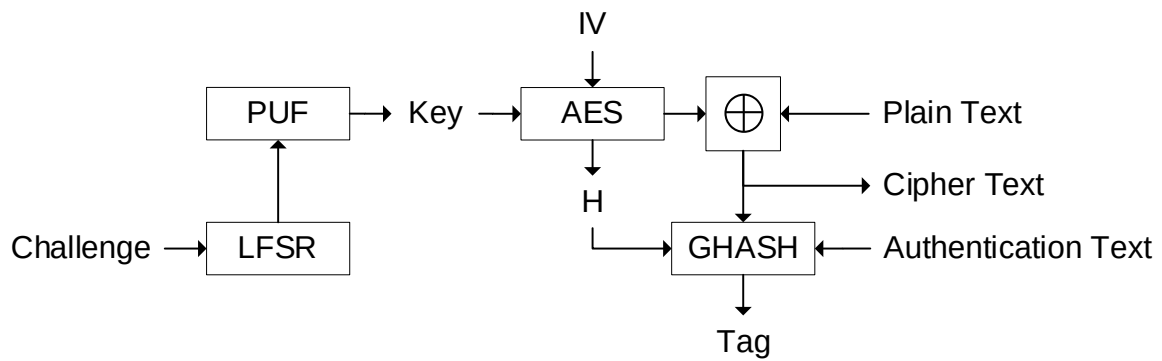


圖 4-3. 使用物理不可複製函數為金鑰之進階加密標準－伽羅瓦/計數器模式的加密

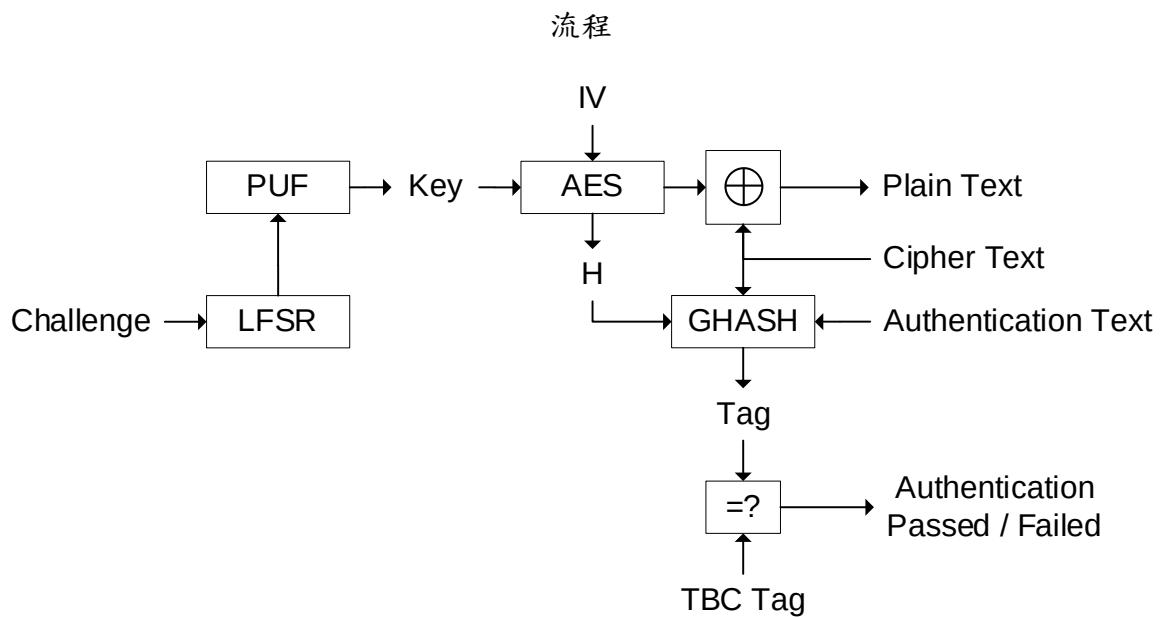


圖 4-4. 使用物理不可複製函數為金鑰之進階加密標準－伽羅瓦/計數器模式的解密

流程

4.1.3 記憶體保護元件與周邊鎖

本平台使用記憶體保護元件及周邊鎖(peripheral lock)產生可信任的執行環境，其架構如圖 4-5 所示，通過配置記憶體保護元件將需要保護區塊的鎖開啟，特權核心可以禁止使用者核心存取該區塊的內容，被保護的區塊有靜態隨機存取記憶體(static random access memory, SRAM)、開機唯讀記憶體、非同步收發傳輸器、序列周邊介面、

通用輸入/輸出及安全模組的進階加密標準和物理不可複製函數，其中靜態隨機存取記憶體分成 8 個區塊，特權核心可以根據需求鎖定不同的記憶體區塊。

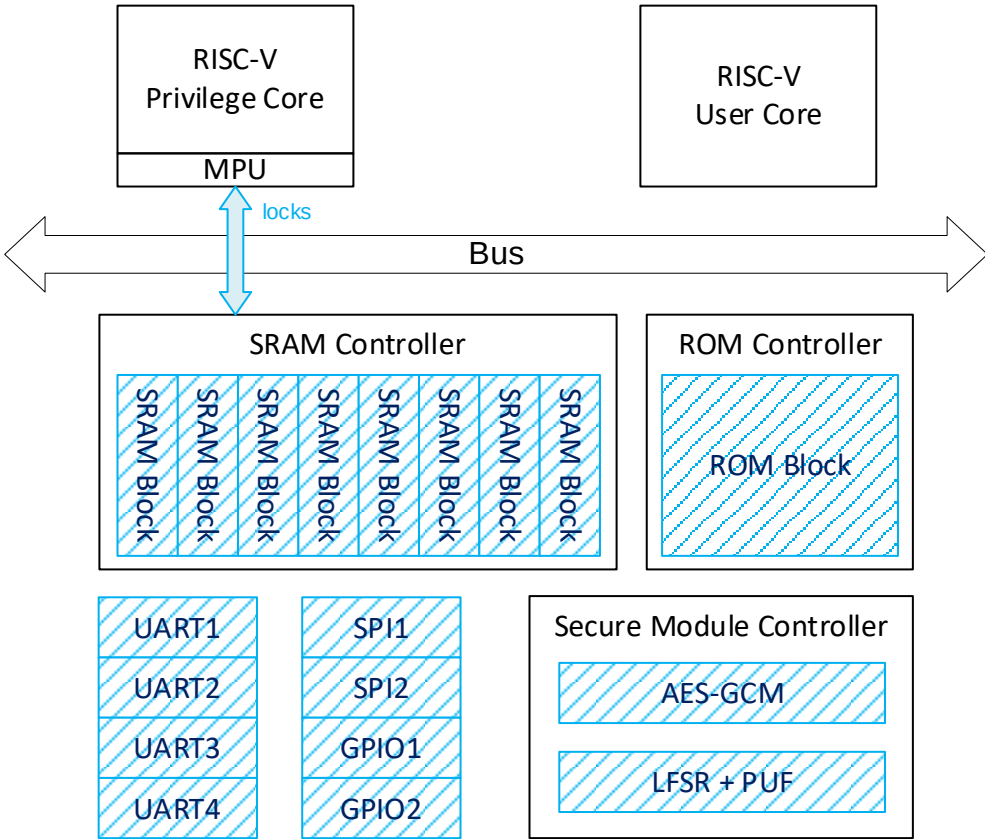


圖 4-5. 記憶體保護裝置與周邊鎖架構，斜線為保護的部分

4.2 韌體保護及認證機制

因為物聯網晶片資源有限，本平台將韌體、作業系統及檔案資料儲存在晶片外的序列周邊介面快閃記憶體(SPI Flash)，為了驗證程式碼的完整性，本平台使用特權核心、安全模組與開機唯讀記憶體作為裝置的信任根，並使用信任鏈解密及驗證位於晶片外的開機讀取器及作業系統。

信任根的架構如圖 4-6(a)所示，特權核心讀取加密的韌體，並將加密的韌體送到安全模組解密並進行認證，並將解密過後的韌體儲存在晶片上的隨機存取記憶體上；信任鏈的流程如圖 4-6(b)所示，晶片剛開機或是經過重置(reset)之後，特權核心會先

讀取位於開機唯讀記憶體中的第一階段開機讀取器，因為特權核心需要執程式碼來開始信任鏈的流程且唯讀記憶體無法經由電子的方式被更改，這段程式碼不需被加密，第一階段開機讀取器從快閃記憶體讀取第二階段開機讀取器，將加密的程式碼送進安全模組進行解密，然後驗證產生的標籤是否與儲存在快閃記憶體的標籤相等，失敗的話則取消開機流程，成功的話特權核心會開始執行第二階段開機讀取器，並以相同的方式驗證作業系統的完整性。

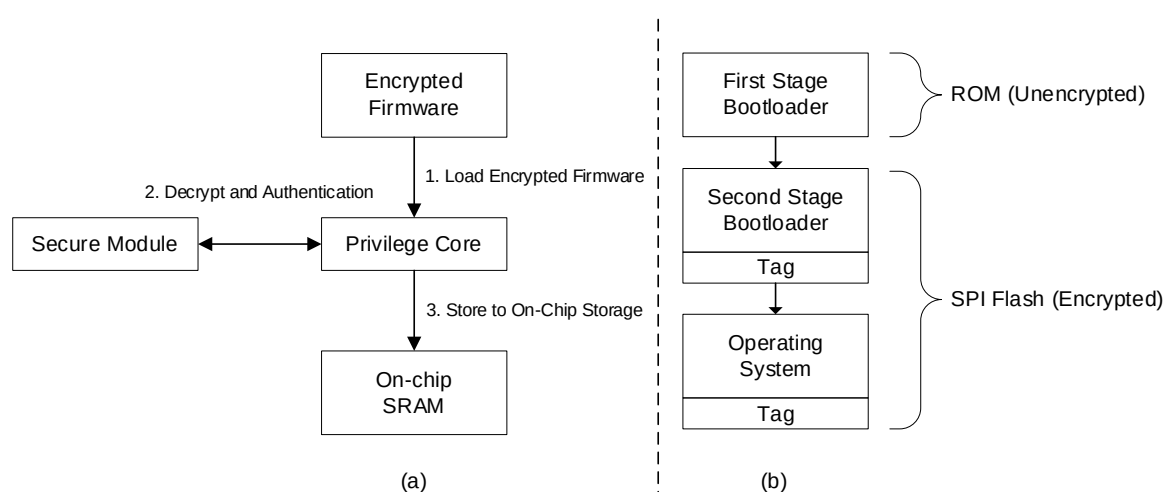


圖 4-6. 以(a)信任根及(b)信任鏈作為韌體的保護機制

使用此保護方式可以降低對手分析韌體程式碼並竄改的可能性，只要對手無法取得金鑰，解密、竄改、加密韌體的程式碼及產生正確的標籤會非常困難，防止對手取得金鑰的方式會在 4.3 節進行詳細的說明。

4.3 攻擊模型及反制方式

本平台主要的攻擊模型為竊取進階加密標準的金鑰，對手可以藉由建立不可複製函數的模型來取得金鑰，假設對手的能力如下：瞭解本平台的系統架構、擁有裝置的物理存取權，後者代表對手可以竊聽系統的輸入/輸出、撰寫運行在使用者核心上的惡意程式及對系統執行功率旁路攻擊。金鑰可能的洩漏途徑分別為：使用者核心讀出

物理不可複製函數的響應值；特權核心植入惡意軟體；使用功率旁路攻擊分析金鑰暫存器來建立物理不可複製函數的模型，分別在以下幾節介紹。

4.3.1 使用者核心讀出物理不可複製函數的響應值

因為對手瞭解本平台的系統架構，並且會撰寫運行在使用者核心上的惡意程式，對手可以直接從安全模組讀取物理不可複製函數的響應值，金鑰會因此洩漏出去。反制的方式如圖 4-7 所示，裝置在開機完成之後，特權核心使用記憶體保護元件建立可信任的執行環境，禁止使用者核心存取安全模組，如果使用者核心需要使用安全模組，必須執行軟體中斷(software interrupt)請求特權核心來處理，特權核心可以拒絕針對物理不可複製函數的非法存取。使用此方式可以維持信任根的安全性，並且也不會失去進階加密標準作為加速硬體的功用。

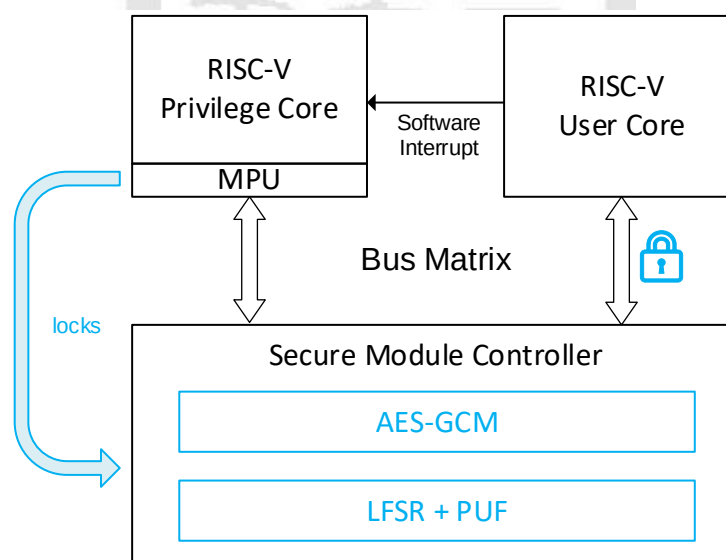


圖 4-7. 使用者核心存取安全模組的反制方式

4.3.2 特權核心植入惡意軟體

因為對手瞭解本平台的系統架構，並且會撰寫運行在使用者核心上的惡意程式，但是受限於 4.3.1 節提出的對策，使用者核心無法請求特權核心讀取物理不可複製函數的響應值，但是可以請求特權核心以不可複製函數響應值為金鑰的加密或解密行為，對手因此可以輕易地解密儲存在晶片外的韌體、植入惡意軟體、重新加密韌體，使用被感染的韌體可以直接獲得裝置的控制權。反制的方式如圖 4-8 所示，裝置在開機完成之後，請求的物理不可複製函數響應值將會經由雜湊函數變成新的金鑰，如圖 4-8(a) 所示，以伽羅瓦/計數器模式作為雜湊函式，第二階段開機讀取器的挑戰值會先儲存於晶片上，並用來產生雜湊的金鑰，請求的挑戰值為初始向量，額外認證資料、明文及密文都不使用，產生的標籤為內部挑戰值，成為接下來的加密或解密的金鑰，流程如圖 4-8(b) 所示。使用此方式可以讓開機後的加密與解密流程不會使用與開機韌體相同的金鑰，開機韌體的金鑰為 $PUF(C)$ ，如果開機後加密或解密使用的金鑰為 $E(PUF(C), C_{req})$ ，兩者相等的機率趨近於 0，其中 C 為開機的挑戰值、 C_{req} 為請求的挑戰值、 PUF 為使用物理不可複製函數產生金鑰， E 為進階加密標準使用前面的金鑰加密後面的初始向量。

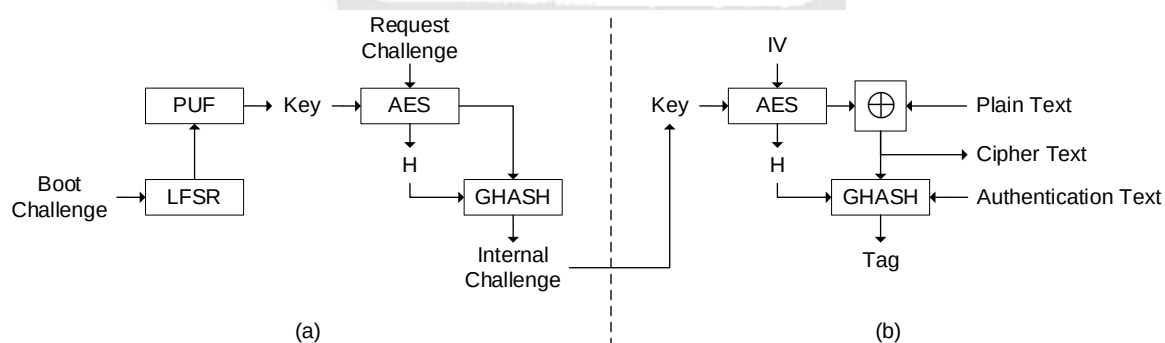


圖 4-8. 特權核心植入惡意軟體的反制方式，以(a)伽羅瓦/計數器模式為雜湊函式產生金鑰並進行(b)加密或解密的流程

4.3.3 功率旁路攻擊分析金鑰暫存器

因為對手瞭解本平台的系統架構，並且擁有裝置的物理存取權，對手無法透過惡意軟體的方式直接取得物理不可複製函數的響應值，也無法直接植入惡意軟體到韌體內，只能透過旁路攻擊的方式取得金鑰，假設對手通過功率旁路攻擊來建立物理不可複製函數的模型，金鑰暫存器為對手首要的攻擊目標，因為金鑰暫存器會直接儲存從物理不可複製函數傳出的響應值，並利用 3.1.2 節的方式建立物理不可複製函數的模型，對手可以還原出金鑰並取得裝置的控制權。反制的方式為使金鑰暫存器的功耗在金鑰產生的過程中保持相同的增加速率，金鑰暫存器在重置(reset)之後會變為 0，因為仲裁器物理不可複製函數一次只會產生一個響應值，對手可以觀察仲裁器物理不可複製函數產生響應值前後的功率變化，來推測此挑戰值產生的響應值為 1 或是 0，但是如果能讓產生的過程看起來像是每一次都產生 1，對手就無法由此推測出真正的響應值是什麼。產生金鑰的架構如圖 4-9 所示，物理不可複製函數使用[44]提出的差動仲裁器物理不可複製函數，此物理不可複製函數在原有的架構上加入另一個仲裁器，如圖 4-10 所示，此仲裁器時鐘與資料的輸入與原本的仲裁器相反，輸出的響應值也會與原本的相反，兩個響應值會分別輸入金鑰暫存器與互補的金鑰暫存器，每一個時間點同時只會有一個位元為 1，而對手無法從外部的功耗知道正確的響應值，因此也無法建立物理不可複製函數的模型。

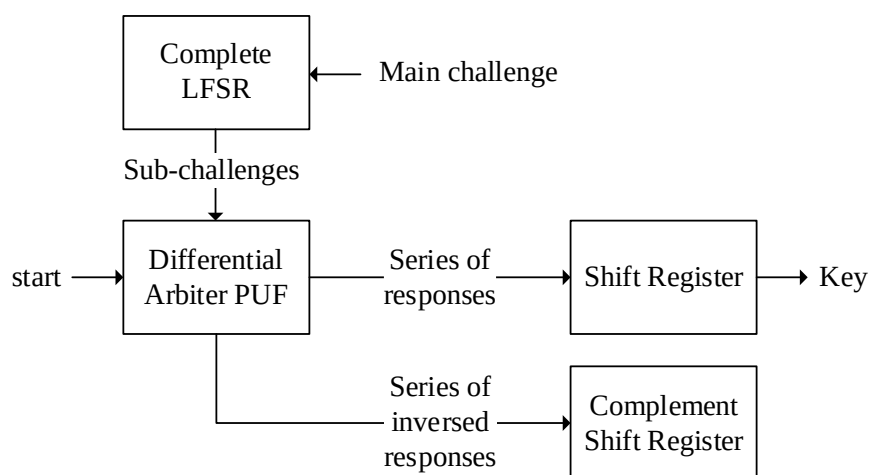


圖 4-9. 平衡物理不可複製函數及金鑰暫存器功耗的架構

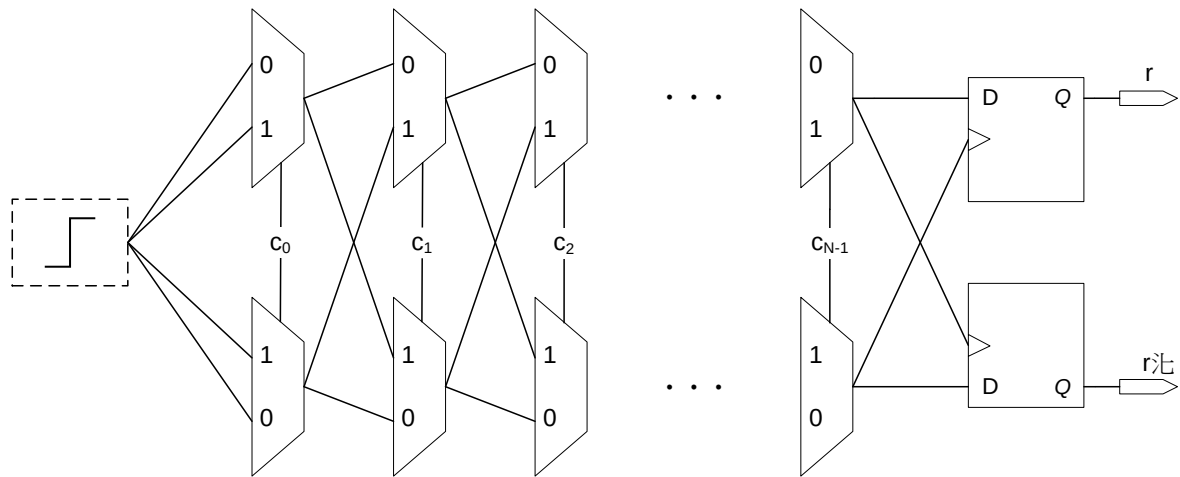


圖 4-10. 差動仲裁器物理不可複製函數架構

4.4 硬體及韌體安全

本系統的硬體及韌體安全如圖 4-11 所示，系統由特權核心、進階加密標準—伽羅瓦/計數器模式、物理不可複製函數及開機唯讀記憶體組成信任根，為裝置提供硬體安全性，信任鏈使用信任根驗證及保護韌體，藉由可信任的韌體建立可信任的執行環境，為裝置提供韌體安全性，此可信任的執行環境由特權核心、記憶體保護元件、周邊鎖及獨立的隨機存取記憶體組成，並運行對抗金鑰竊取的對策保護物理不可複製函數，當物理不可複製函數保持可信任，信任根就不會被破壞，讓下一次開機也能維持系統安全。

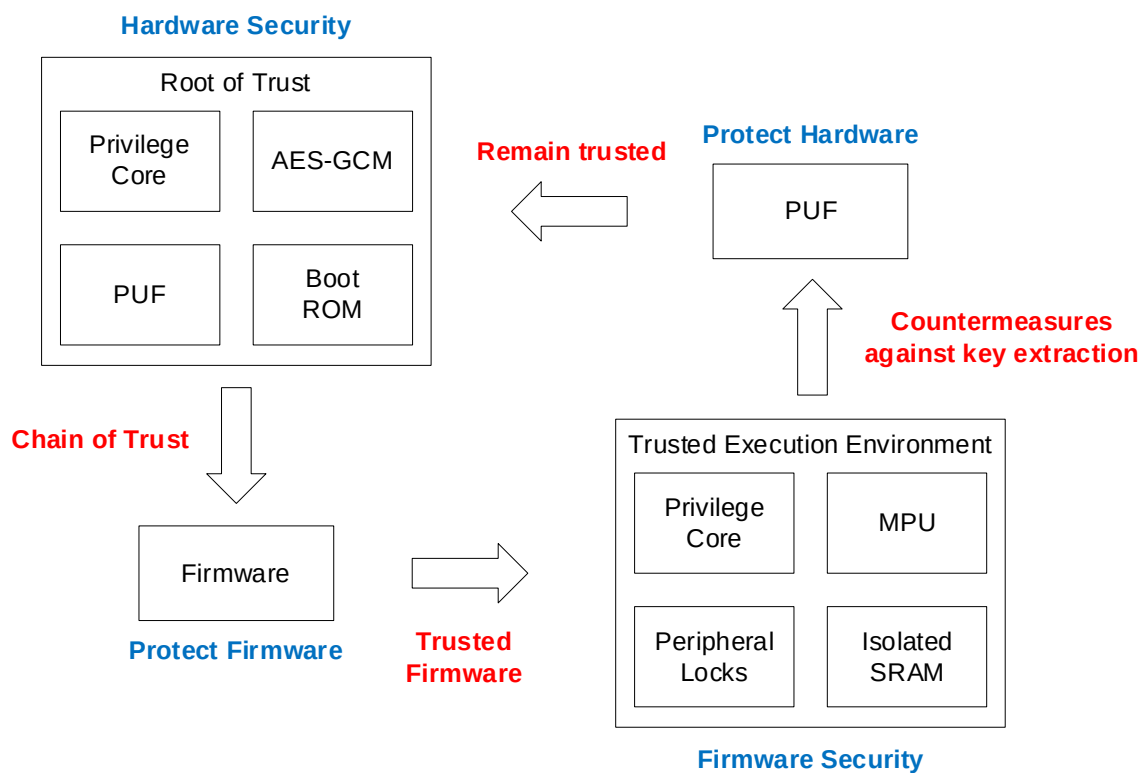


圖 4-11. 硬體及韌體安全



第 5 章 實驗結果與分析

本章節將藉由實驗分析平衡金鑰暫存器功耗的效益，在 5.1 節介紹實驗的環境設置，在 5.2 節分析實驗結果。

5.1 實驗環境設置

5.1.1 實驗目標與對象

如同前述，分析平衡金鑰暫存器功耗的效益是本實驗的目標，我們需要扮演對手建立物理不可複製函數模型的角色，分析加入此防護機制對模型準確度的影響，換句話說，我們必須在每次建立物理不可複製函數模型的時候，讓模型準確度盡量達到最高，並且得到當加入此防護機制對模型準確度下降的程度。

實驗的對象為標準的仲裁器物理不可複製函數和差動仲裁器物理不可複製函數，架構分別如圖 2-3 及圖 4-10 所示，第一個實驗直接使用挑戰值和響應值來訓練這兩種物理不可複製函數，此實驗是要確認所使用的挑戰響應對能達到的準確度，當成後一個實驗的比較基礎，實際上對手無法直接取得挑戰響應對來訓練模型；第二個實驗會使用挑戰值和 1 位元漢明重量的功率模型來訓練這兩種物理不可複製函數，此實驗的結果與第一個實驗比較即可獲得此防護機制效益。

5.1.2 實驗工具與流程

本實驗使用的工具如表 5-1 所示，本實驗使用台積電 40 奈米製程，實驗的步驟如下：

- a. 合成物理不可複製函數並在一定範圍內隨機指定元件之間的延遲數值。因為合成軟體會將元件之間的延遲數值設定成同一個數值，通常是最大的延遲數值，實際

上物理不可複製函數會因為製程的變異而產生不同的延遲數值，所以必須更改延遲數值來模擬物理不可複製函數。

- b. 跑模擬取得特定挑戰值的響應值以及波形。因為訓練物理不可複製函數需要一些挑戰響應對或是挑戰功耗對，為了使用相同的挑戰值來訓練，我們會記錄該挑戰值對應的響應值以及功率，波形用於取得功率消耗值。
- c. 由波形取得該挑戰值的功率。數位電路的功率消耗可以透過邏輯閘層次(gate-level)的網表(netlist)以及其波形圖取得。
- d. 使用挑戰響應對或挑戰功耗對訓練物理不可複製函數的模型。
- e. 測試物理不可複製函數的準確率。

表 5-1. 實驗工具

Usage	Tool Name
Synthesis	Synopsys Design Compiler
Simulation	Cadence Incisive Enterprise Simulator
Power Extraction	Synopsys PrimeTime PX
PUF Model Training and Testing	CMA-ES/pycma[45] (Python)

5.1.3 機器學習方式

本實驗使用自適應共變異數矩陣演化策略來訓練物理不可複製函數的模型，因為選用仲裁器物理不可複製函數，我們以延遲加法模型作為訓練的模型，演化策略的設定如表 5-2 所示，因為延遲加法模型需要 $N + 1$ 個參數，其中 N 為交換器的數量，在本平台為 128；初始權重代表參數的初始值，演化策略會進行數次的訓練來更新權重數值，直到結果無法再被優化為止；初始步進數值會影響參數改變的大小，因為兩條路徑延遲時間的總和會經由仲裁器判斷大小才輸出響應值，所以不會影響預測的響應

值；生成數量為每一次演化策略會產生多少數量的變異子代，之後會選擇結果最佳的子代當成下一次的父代，本實驗使用工具提供的預設值 $4 + \lfloor 3 \times \ln(N + 1) \rfloor = 18$ 。

表 5-2. 自適應共變異數矩陣演化策略的參數設定

Configuration	Value
Input Dimension	129
Initial Weight Value	0
Initial Step Size	2
Population Size	18 (Default)

本實驗總共量測 20000 組不同的挑戰響應對及挑戰功耗對，其中 16000 組挑戰響應對和挑戰功耗對用來訓練延遲加法模型，另外 4000 組用來測試物理不可複製函數的準確度。

5.2 實驗結果

5.2.1 使用挑戰響應對訓練物理不可複製函數模型

使用自適應共變異數矩陣演化策略訓練模型需要提供合適度(fitness)，讓演化策略能找到最適合的子代，因為此實驗使用挑戰響應對訓練模型，我們選擇模型響應值 $\hat{r}$ 與實際響應值 r 的不同的數量，亦即響應值錯誤的數目，為演化策略的合適度。

標準仲裁器物理不可複製函數及差動仲裁器物理不可複製函數的實驗結果分別如圖 5-1 和圖 5-2 所示，可以看到經過 100 次迭代之後，兩者響應值錯誤的數量都小於 800，意即訓練資料集(training set)準確率皆超過 95%；經過 400 次迭代之後，準確率大致已經呈現固定的狀態。最終標準仲裁器物理不可複製函數的測試資料集(testing set)準確率為 98.95%，差動仲裁器物理不可複製函數的測試資料集準確率為 97.325%。

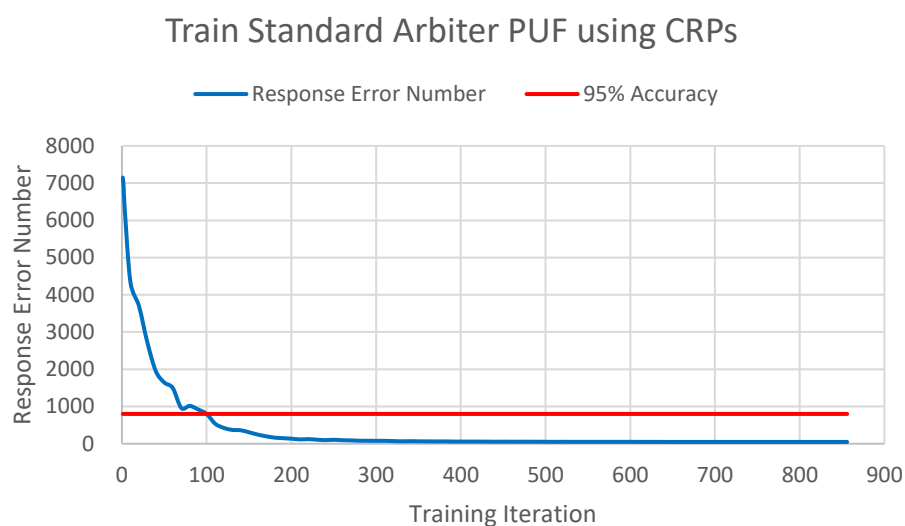


圖 5-1. 使用挑戰響應對訓練標準仲裁器物理不可複製函數

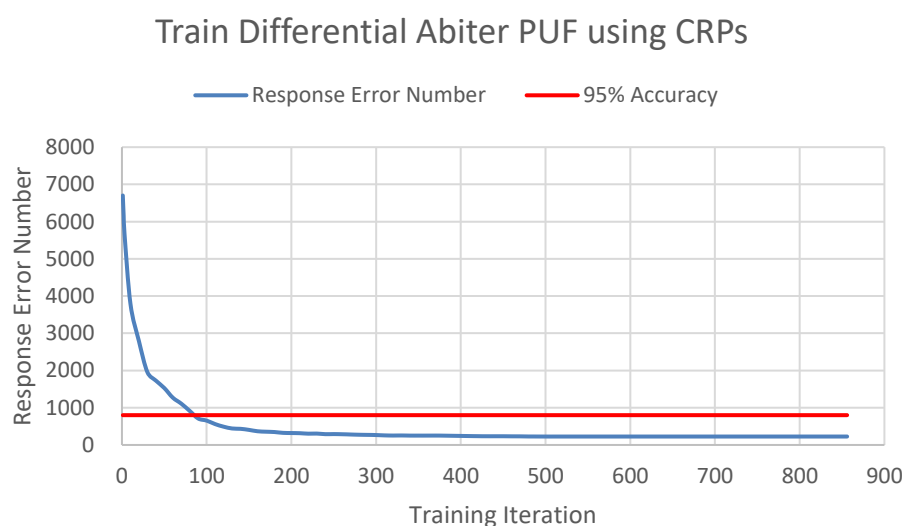


圖 5-2. 使用挑戰響應對訓練差動仲裁器物理不可複製函數

由此實驗結果可以發現，如果挑戰響應對洩漏出去，可能會造成整體系統安全性被破壞，而兩者準確率不同的原因有三個，第一個為兩個物理不可複製函數所使用的交換器有不同的延遲時間，第二個為使用的挑戰值不一樣，最後一個是自適應共變異數矩陣演化策略在生成子代的時候會用到隨機數，所以每一次訓練的結果都不太一樣，但是都能收斂到很高的準確率。

5.2.2 使用挑戰功耗對訓練物理不可複製函數模型

此實驗使用挑戰功耗對訓練模型，因為本論文提出的機制，對手實際上無法取得挑戰響應對，但是可以記錄此挑戰值讓電路產生的功耗，並且利用模型響應值 $\hat{r}$ 與電路功耗值 P 的相關係數 $\rho_{\hat{r},P}$ 來代表模型的合適度。此實驗使用的功耗值只有物理不可複製函數及暫存器的功耗，因為防治方式如果能在無雜訊的狀況下有效降低模型的準確度，加上雜訊只會降低模型的準確度，這也是此實驗採用 1 位元漢明重量功率模型的原因之一。

標準仲裁器物理不可複製函數及差動仲裁器物理不可複製函數的實驗結果分別如圖 5-3 和圖 5-4 所示，可以看到標準仲裁器物理不可複製函數的結果與前一個實驗大致相同，訓練資料集準確率在 100 次迭代之後就超過 95%，響應值與功耗值的相關係數超過 0.9；相反地，差動仲裁器物理不可複製函數的訓練資料集準確率到最後都無法超過 75%，響應值與功耗值的相關係數大約為 0.1 左右。最終標準仲裁器物理不可複製函數的測試資料集準確率為 99.175%，差動仲裁器物理不可複製函數的測試資料集準確率為 69.25%。

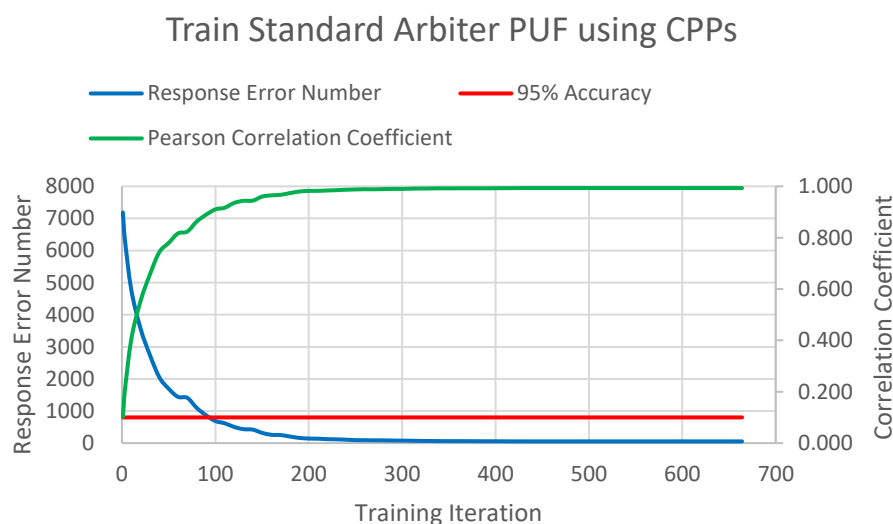


圖 5-3. 使用挑戰功耗對訓練標準仲裁器物理不可複製函數

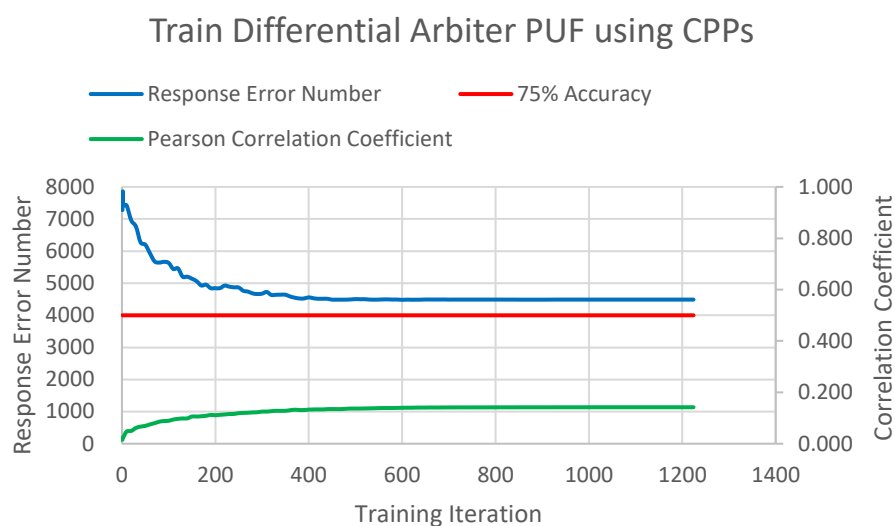


圖 5-4. 使用挑戰功耗對訓練差動仲裁器物理不可複製函數

由此實驗結果可以發現，本論文提出平衡金鑰暫存器功耗的方式可以使模型準確率有 28.85% 的降低幅度，並且讓響應值與功耗值的相關係數降低 85.7%。

第 6 章 結論和未來工作

6.1 結論

本論文提出一針對物聯網 RISC-V 系統的韌體及硬體安全架構，並對金鑰竊取的攻擊模型及反制方式進行分析。此平台包含特權核心(privilege core)、進階加密標準—伽羅瓦/計數器模式(AES-GCM)、物理不可複製函數(PUF)、記憶體保護元件(MPU)和周邊鎖(peripheral lock)組成的信任根，來提供裝置硬體安全，並且提出一個使用信任鏈的安全開機流程保護及認證韌體，攻擊模型針對金鑰可能洩漏的途徑進行分析，並提出使用硬體及韌體的方式來保護系統安全，達成可信任的執行環境。

與相關文獻[41]的比較如表 6-1 所示，相關文獻[41]主要使用非對稱式加密演算法來加密韌體的簽章，公鑰在出廠時會燒錄到晶片內供開機解密時使用，開機流程由硬體的控制器負責每個階段的認證；本論文則是使用對稱式加密演算法來加密韌體，並且利用物理不可複製函數讓每個晶片擁有獨特的金鑰，開機流程由軟體來認證，並且利用硬體的進階加密標準加快解密及認證的速度。

表 6-1. 本論文與相關文獻比較

	Related Work [41]	Proposed Platform
Publication	ISQED'19	Unpublished
Root of Trust	Code Authentication Unit (CAU), Key Management Unit (KMU) & Boot Sequencer	Privilege Core, AES-GCM, PUF, Boot ROM
Boot Flow Control	Hardware Based Boot Sequencer	Software Based Sequencer with Hardware AES-GCM
Firmware Encryption	None	AES Counter-mode
Code Authentication	SHA-3 & ECDSA (Asymmetric-key Algorithm)	PUF & AES-GCM (Symmetric-key Algorithm)
Key Generation	Fused Public Key	PUF
Countermeasures against Side Channel Attacks	Secure Debug & Trusted Execution Environment	Trusted Execution Environment & Anti-differential Power Analysis

針對功率旁路攻擊提出的防治方式做實驗，結果顯示平衡金鑰暫存器可以讓模型準確率降低到只剩 69.25%，與原本相比降低了 28.85%，同時讓響應值與功耗值的相關係數降低 85.7%。

6.2 未來工作

本論文的未來工作可以針對下列幾點加強：

■ 使用現場可程式化邏輯閘陣列驗證系統功能的正確性和進行實驗

本平台目前有部分元件已經由現場可程式化邏輯閘陣列驗證功能的正確性，但尚未進行完整的功能驗證，物理不可複製函數的實驗目前僅運行在邏輯閘層次，功耗也是使用製程廠提供的元件功率資訊，可能會導致實驗結果過於樂觀。

■ 加入錯誤更正碼元件及其安全流程

因為仲裁器物理不可複製函數的可靠度並非百分之百，將其響應值使用在對輸入非常敏感的進階加密標準中，任何一個位元錯誤都可能導致加密或解密的結果完全不同，所以導入錯誤更正碼是必要的，但是其輔助資料會是對手攻擊的目標之一[46]，目前的想法為將輔助資料加入伽羅瓦/計數器模式的額外認證資料，對手修改輔助資料或是標籤都會導致軟體認證失敗。

參考文獻

- [1] J. Gubbi, R. Buyya, S. Marusic, and M. Palaniswami, “Internet of Things (IoT): A Vision, Architectural Elements, and Future Directions,” *Future Generation Computer Systems*, vol. 29, no. 7, pp. 1645–1660, Sep. 2013.
- [2] P. Newman, “The Internet of Things 2020: Here’s What Over 400 IoT Decision-Makers Say About the Future of Enterprise Connectivity and How IoT Companies Can Use It to Grow Revenue,” *Business Insider*.
<https://www.businessinsider.com/internet-of-things-report> (accessed Jun. 10, 2020).
- [3] “The Ultimate List of Cyber Security Statistics for 2019,” *Purplesec*.
<https://purplesec.us/resources/cyber-security-statistics> (accessed Jun. 09, 2020).
- [4] A. Waqas, “Mirai Botnet Linked to Massive DDoS Attacks on Dyn DNS,” *HackRead*.
<https://www.hackread.com/mirai-botnet-linked-to-dyn-dns-ddos-attacks> (accessed Jun. 10, 2020).
- [5] M. Fagan, K. N. Megas, K. Scarfone, and M. Smith, “IoT Device Cybersecurity Capability Core Baseline,” National Institute of Standards and Technology, NIST Internal Report 8259A, 2020. [Online]. Available:
<https://nvlpubs.nist.gov/nistpubs/ir/2020/NIST.IR.8259.pdf>.
- [6] S. P. Skorobogatov, “Semi-Invasive Attacks - a New Approach to Hardware Security Analysis,” Computer Laboratory, University of Cambridge, Technical Report UCAM-CL-TR-630, 2005.
- [7] U. Rührmair, F. Sehnke, J. Sölter, G. Dror, S. Devadas, and J. Schmidhuber, “Modeling Attacks on Physical Unclonable Functions,” in *Proc. 17th ACM Conference on Computer and Communications Security*, 2010, pp. 237–249.

- [8] X. Xu and W. Burleson, "Hybrid Side-Channel/Machine-Learning Attacks on PUFs: A New Threat?," in *Proc. 2014 Design, Automation & Test in Europe Conference & Exhibition*, Apr. 2014, pp. 1–6.
- [9] A. Regenscheid, "Platform Firmware Resiliency Guidelines," National Institute of Standards and Technology, NIST Special Publication 800–193, 2018. [Online]. Available: <http://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-193.pdf>.
- [10] "TrustZone for Cortex-A," ARM. <https://developer.arm.com/ip-products/security-ip/trustzone/trustzone-for-cortex-a> (accessed Jun. 11, 2020).
- [11] "Secure Technology," AMD. <https://www.amd.com/en/technologies/security> (accessed Jun. 11, 2020).
- [12] "New Microarchitecture for 4th Gen Intel® Core™ Processor Platforms," Intel, 2013. [Online]. Available: <https://www.intel.com/content/dam/www/public/us/en/documents/product-briefs/4th-gen-core-family-mobile-brief.pdf>.
- [13] J. Delvaux, R. Peeters, D. Gu, and I. Verbauwhede, "A Survey on Lightweight Entity Authentication with Strong PUFs," *ACM Computing Surveys*, vol. 48, no. 2, pp. 26:1–26:42, 2015.
- [14] D. E. Holcomb, W. P. Burleson, and K. Fu, "Power-Up SRAM State as an Identifying Fingerprint and Source of True Random Numbers," *IEEE Transactions on Computers*, vol. 58, no. 9, pp. 1198–1210, 2009.
- [15] G. E. Suh and S. Devadas, "Physical Unclonable Functions for Device Authentication and Secret Key Generation," in *Proc. 2007 44th ACM/IEEE Design Automation Conference*, 2007, pp. 9–14.

- [16] J. W. Lee, D. Lim, B. Gassend, G. E. Suh, M. van Dijk, and S. Devadas, “A Technique to Build a Secret Key in Integrated Circuits for Identification and Authentication Applications,” in *Proc. 2004 Symposium on VLSI Circuits*, 2004, pp. 176–179.
- [17] G. T. Becker, “The Gap Between Promise and Reality: On the Insecurity of XOR Arbiter PUFs,” in *Proc. International Workshop on Cryptographic Hardware and Embedded Systems*, 2015, vol. 9293, pp. 535–555.
- [18] M. Majzoobi, F. Koushanfar, and M. Potkonjak, “Lightweight Secure PUFs,” in *Proc. IEEE/ACM International Conference on Computer-Aided Design*, 2008, pp. 1–4.
- [19] U. Rührmair *et al.*, “Power and Timing Side Channels for PUFs and Their Efficient Exploitation,” IACR Cryptology ePrint Archive, 2013. [Online]. Available: <https://eprint.iacr.org/2013/851.pdf>.
- [20] B. Gassend, D. Lim, D. Clarke, M. van Dijk, and S. Devadas, “Identification and Authentication of Integrated Circuits,” *Concurrency and Computation: Practice and Experience*, vol. 16, no. 11, pp. 1077–1098, Sep. 2004.
- [21] Q. Tang, W. H. Choi, L. Everson, K. K. Parhi, and C. H. Kim, “A Physical Unclonable Function Based on Capacitor Mismatch in a Charge-Redistribution SAR-ADC,” in *Proc. 2018 IEEE International Symposium on Circuits and Systems*, 2018, pp. 1–5.
- [22] F. Rosenblatt, “The Perceptron, a Perceiving and Recognizing Automaton (Project Para),” Cornell Aeronautical Laboratory, Report 85-460–1, 1957.
- [23] J. Sölter, “Cryptanalysis of Electrical PUFs via Machine Learning Algorithms,” M.S. thesis, Department of Informatics, Technical University of Munich, Munich, Bavaria, Germany, 2009.
- [24] “History of Support Vector Machines,” SVM Learning. <https://www.svms.org/history.html> (accessed Jun. 22, 2020).

- [25] C. Cortes and V. Vapnik, "Support-Vector Networks," *Machine Learning*, vol. 20, no. 3, pp. 273–297, 1995.
- [26] B. Gassend, D. Clarke, M. van Dijk, and S. Devadas, "Controlled Physical Random Functions," in *Proc. 18th Annual Computer Security Applications Conference*, 2002, pp. 149–160.
- [27] G. T. Becker and R. Kumar, "Active and Passive Side-Channel Attacks on Delay Based PUF Designs," IACR Cryptology ePrint Archive, 2014. [Online]. Available: <http://eprint.iacr.org/2014/287.pdf>.
- [28] C. Bösch, J. Guajardo, A. R. Sadeghi, J. Shokrollahi, and P. Tuyls, "Efficient Helper Data Key Extractor on FPGAs," in *Proc. 10th International Workshop on Cryptographic Hardware and Embedded Systems*, 2008, pp. 181–197.
- [29] J. Delvaux and I. Verbauwhede, "Attacking PUF-Based Pattern Matching Key Generators via Helper Data Manipulation," in *Proc. Cryptographer's Track at the RSA Conference 2014*, 2014, pp. 106–131.
- [30] G. T. Becker, "On the Pitfalls of Using Arbiter-PUFs as Building Blocks," *IEEE Transactions on Computer-Aided Design of Integrated Circuits and Systems*, vol. 34, no. 8, pp. 1295–1307, Aug. 2015.
- [31] D. Nedospasov, J.-P. Seifert, C. Helfmeier, and C. Boit, "Invasive PUF Analysis," in *Proc. 10th Workshop on Fault Diagnosis and Tolerance in Cryptography*, 2013, pp. 30–38.
- [32] S. Tajik *et al.*, "Photonic Side-Channel Analysis of Arbiter PUFs," *Journal of Cryptology*, vol. 30, no. 2, pp. 550–571, Apr. 2017.
- [33] D. Merli, D. Schuster, F. Stumpf, and G. Sigl, "Semi-Invasive EM Attack on FPGA RO PUFs and Countermeasures," in *Proc. Workshop on Embedded Systems Security*, 2011, pp. 1–9.

- [34] “Advanced Encryption Standard (AES),” National Institute of Standards and Technology, Federal Information Processing Standards Publication 197, 2001. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/FIPS/NIST.FIPS.197.pdf>.
- [35] “Brute-Force Attack,” Wikipedia. https://en.wikipedia.org/wiki/Brute-force_attack (accessed Jun. 25, 2020).
- [36] M. Dworkin, “Recommendation for Block Cipher Modes of Operation: Methods and Techniques,” National Institute of Standards and Technology, NIST Special Publication 800–38A, 2001. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-38a.pdf>.
- [37] M. Dworkin, “Recommendation for Block Cipher Modes of Operation: Galois/Counter Mode (GCM) and GMAC,” National Institute of Standards and Technology, NIST Special Publication 800–38D, 2007. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-38d.pdf>.
- [38] D. A. McGrew and J. Viega, “The Security and Performance of the Galois/Counter Mode (GCM) of Operation,” in *Proc. 5th International Conference on Cryptology in India*, 2004, pp. 343–355.
- [39] G. Pocklassery, W. Che, F. Saqib, M. Areno, and J. Plusquellic, “Self-Authenticating Secure Boot for FPGAs,” in *Proc. 2018 IEEE International Symposium on Hardware Oriented Security and Trust*, 2018, pp. 221–226.
- [40] J. Aarestad, P. Ortiz, J. Plusquellic, and D. Acharyya, “HELP: A Hardware-Embedded Delay PUF,” *IEEE Design and Test*, vol. 30, no. 2, pp. 17–25, 2013.
- [41] J. Haj-Yahya, M. M. Wong, V. Pudi, S. Bhasin, and A. Chattopadhyay, “Lightweight Secure-Boot Architecture for RISC-V System-on-Chip,” in *Proc. 20th International Symposium on Quality Electronic Design*, 2019, pp. 216–223.

- [42] “SCR1 Microcontroller Core,” Syntacore.
<https://syntacore.com/page/products/processor-ip/scr1> (accessed Jul. 02, 2020).
- [43] “SCR1 External Architecture Specification,” Syntacore, 2019. [Online]. Available:
https://github.com/syntacore/scr1/blob/master/docs/scr1_eas.pdf.
- [44] A. Mahmoud, U. Rührmair, M. Majzoobi, and F. Koushanfar, “Combined Modeling and Side Channel Attacks on Strong PUFs,” IACR Cryptology ePrint Archive, 2013. [Online]. Available: <https://eprint.iacr.org/2013/632.pdf>.
- [45] N. Hansen, Y. Akimoto, and P. Baudis, “CMA-ES/pycma,” Zenodo.
<https://doi.org/10.5281/zenodo.2559634> (accessed Jun. 19, 2020).
- [46] G. T. Becker, “Robust Fuzzy Extractors and Helper Data Manipulation Attacks Revisited: Theory vs Practice,” *IEEE Transactions on Dependable and Secure Computing*, vol. 16, no. 5, pp. 783–795, 2019.